

[TÊN TRƯỜNG / KHOA]

ĐỒ ÁN / LUẬN VĂN

TRỢ LÝ SĂN MỐI ĐE DỌA DỰA TRÊN PEAK ASSISTANT

Thực thi tất định trên telemetry và khuyến nghị hỗ trợ người quyết định

*(AI Agent Hunting v7: tích hợp PEAK Assistant của Cisco Talos, kiểm chứng trên bộ dữ liệu
Boss of the SOC v1)*

Sinh viên thực hiện: [Họ và tên]

Mã số sinh viên: [MSSV]

Giảng viên hướng dẫn: [Học hàm, học vị, họ và tên]

[Địa điểm], [tháng/năm]

LỜI CAM ĐOAN

Tôi xin cam đoan đây là công trình nghiên cứu của riêng tôi dưới sự hướng dẫn của giảng viên hướng dẫn. Các số liệu và kết quả thực nghiệm trong đề án là trung thực, được sinh ra từ mã nguồn và dữ liệu đi kèm (kho AI_Agent_Hunting, thư mục results/); các tài liệu tham khảo đều được trích dẫn rõ nguồn.

Họ tên sinh viên: [Họ và tên] Chữ ký: _____

TÓM TẮT

Săn mồi đe dọa (threat hunting) là hoạt động chủ động tìm những xâm nhập mà cơ chế phát hiện tự động bỏ sót. Khung PEAK của Splunk SURGe chia mỗi cuộc săn thành ba pha Prepare, Execute và Act, trong đó pha Prepare (chọn chủ đề, nghiên cứu, giả thuyết, mô hình ABLE, phạm vi, kế hoạch) tốn nhiều công sức nhưng lại phù hợp để trợ lý trí tuệ nhân tạo hỗ trợ. Cisco Talos đã công bố mã nguồn mở PEAK Assistant, một tập tác tử dùng mô hình ngôn ngữ lớn (LLM) để viết báo cáo nghiên cứu, bảng ABLE và kế hoạch săn.

Đồ án này xây dựng AI Agent Hunting v7, một hệ thống ghép PEAK Assistant vào một đường thực thi tắt định. Hệ thống nhận một PoC (giả thuyết đã cụ thể hoá thành các vị từ trường - phép so sánh - giá trị), nhờ PEAK Assistant viết bảng ABLE và kế hoạch săn, chạy các vị từ trên telemetry (SQLite hoặc Splunk), kiểm tra độ phủ của nguồn dữ liệu, rồi sinh một khuyến nghị có xếp hạng, kèm lý do, giới hạn, câu hỏi và rủi ro để **người săn quyết định**. Thiết kế giữ ba nguyên tắc: LLM không tạo hay sửa bằng chứng; kết quả rằng không bao giờ bị đọc thành "sạch" khi nguồn dữ liệu thiếu hoặc chưa chứng minh được; LLM là thành phần tùy chọn, hệ thống vẫn chạy và vẫn đưa khuyến nghị theo luật khi không có LLM.

Hệ thống được kiểm chứng trên bộ dữ liệu Boss of the SOC v1 (4.417.543 sự kiện) với bốn PoC có sẵn. PoC khai thác Joomla có ít nhất vài nghìn bản ghi khớp (200 bản ghi được giữ làm bằng chứng) và khuyến nghị chuyển IR ở mức tin cậy trung bình, vì dữ liệu chỉ chứng minh hoạt động quét chứ chưa chứng minh khai thác thành công. Ba PoC còn lại không có bản ghi khớp và được khuyến nghị đóng kèm cảnh báo, không phải kết luận "sạch": cửa sổ chỉ phủ một trong hai mươi tám ngày dữ liệu, nguồn có thể thiếu đúng loại sự kiện cần tìm, và một lượt rà soát cuối phát hiện máy được nêu trong ba PoC này không ghi nguồn tương ứng nên các PoC chưa từng được tìm đúng chỗ (đã sửa bằng cách hiển thị phạm vi và chạy lại không lọc máy). Đồ án cũng mô tả các lỗi gặp phải khi vận hành LLM thật (lỗi 404 thoát qua của endpoint, đầu ra JSON không ổn định) và cách xử lý, đồng thời cung cấp hướng dẫn thực hành từ cài đặt đến viết PoC mới.

Từ khóa: săn mồi đe dọa, PEAK, PEAK Assistant, ABLE, mô hình ngôn ngữ lớn, hệ thống đa tác tử, hỗ trợ ra quyết định, Boss of the SOC.

ABSTRACT

Threat hunting looks for intrusions that automated detection misses. The PEAK framework (Splunk SURGe) splits a hunt into Prepare, Execute and Act. Prepare is labour-intensive and well suited to an AI assistant; Cisco Talos released PEAK Assistant, an open-source set of LLM agents that write research reports, ABLE tables and hunt plans.

This project builds AI Agent Hunting v7, which couples PEAK Assistant with a deterministic execution path. Given a PoC (a hypothesis expressed as field - operator - value predicates), the system asks PEAK Assistant for the ABLE table and hunt plan, runs the predicates against telemetry (SQLite or Splunk), checks data-source coverage, and produces a ranked recommendation with reasons, caveats, questions and risks so that a **human hunter decides**. Three principles hold throughout: the LLM never creates or edits evidence; an empty result is never read as "clean" when data is missing or unproven; the LLM is optional and the system still produces rule-based recommendations without it.

The system was evaluated on Boss of the SOC v1 (4,417,543 events) with four existing PoCs. The Joomla PoC matched at least thousands of records (200 kept as evidence) and was recommended for IR escalation at medium confidence, because the data proves scanning but not successful exploitation. The other three PoCs matched nothing and were recommended for closure with caveats rather than declared clean: the window covered one of twenty-eight days, the source may lack the required event type, and a final review found that the host named in these three PoCs does not log the relevant source, so the PoCs had never searched the right place (fixed by disclosing the scope and re-running without the host filter). The thesis also documents the failures met when operating a real LLM (transient 404 responses, unstable JSON output) and how they were handled, and includes a practical guide from installation to authoring new PoCs.

Keywords: threat hunting, PEAK, PEAK Assistant, ABLE, large language models, multi-agent systems, decision support, Boss of the SOC.

MỤC LỤC

TÓM TẮT.....	iii
ABSTRACT	iv
Chương 1. Mở đầu.....	1
1.1. Đặt vấn đề.....	1
1.2. Bối cảnh và động cơ thực hiện	1
1.3. Mục tiêu nghiên cứu.....	2
1.4. Đối tượng và phạm vi.....	2
1.5. Phương pháp nghiên cứu.....	3
1.6. Đóng góp chính	3
1.7. Bố cục luận văn	3
Chương 2. Cơ sở lý thuyết.....	4
2.1. Săn mồi đe dọa	4
2.2. Khung PEAK.....	5
2.3. MITRE ATT&CK và chỉ báo thực thi	6
2.4. Mô hình ngôn ngữ lớn và hệ thống đa tác tử.....	7
2.5. Độ tin cậy của bằng chứng và bằng chứng âm tính	7
2.6. Hỗ trợ ra quyết định.....	8
2.7. Telemetry và bộ dữ liệu Boss of the SOC v1	8
2.8. Tổng hợp: từ lý thuyết đến quyết định thiết kế	8
Chương 3. Phân tích bài toán và yêu cầu hệ thống	10
3.1. Hiện trạng kho mã v6	10
3.2. Vấn đề cần giải quyết	10
3.3. Yêu cầu chức năng	11
3.4. Yêu cầu phi chức năng	11
3.5. Các phương án thiết kế.....	11
3.6. Các bất biến thiết kế	12
Chương 4. Thiết kế hệ thống	13
4.1. Tổng quan kiến trúc.....	13
4.2. Luồng xử lý một PoC	13
4.3. Mô hình dữ liệu	15

4.4. Lớp cầu nối PEAK Assistant.....	16
4.5. Bộ thực thi và adapter.....	16
4.6. Bộ luật khuyến nghị.....	18
4.7. Thiết kế bảo mật và quyền riêng tư	20
4.8. Cấu trúc đầu ra.....	20
Chương 5. Cài đặt hệ thống.....	21
5.1. Môi trường và công nghệ	21
5.2. Cấu trúc mã nguồn.....	21
5.3. Lớp LLM ('llm.py')	22
5.4. Cầu nối PEAK ('prepare.py').....	23
5.5. Bộ thực thi PoC ('poc/agent.py')	24
5.6. Adapter	25
5.7. Khuyến nghị và báo cáo	25
5.8. Dòng lệnh	26
5.9. Kiểm thử	26
Chương 6. Hướng dẫn thực hành	28
6.1. Chuẩn bị môi trường.....	28
6.2. Cấu hình LLM	28
6.3. Chuẩn bị dữ liệu telemetry	29
6.4. Chạy cuộc săn đầu tiên	30
6.5. Đọc và dùng báo cáo	31
6.6. Viết PoC mới	32
6.7. Dùng với Splunk thật.....	33
6.8. Xử lý sự cố.....	33
6.9. Quy trình tái lập kết quả của luận văn.....	34
Chương 7. Thực nghiệm và đánh giá	35
7.1. Thiết lập thực nghiệm.....	35
7.2. Kết quả chính.....	36
7.3. So sánh ba cấu hình	38
7.4. Các lỗi đã phát hiện nhờ thực nghiệm.....	39
7.5. Gọi LLM: miễn phí và độ tin cậy của endpoint	41

7.6. Kiểm thử đơn vị và tính hồi quy.....	42
7.7. Đánh giá theo yêu cầu	42
7.8. Thời gian chạy	43
7.9. Điều chưa được kiểm chứng.....	43
Chương 8. Thảo luận	45
8.1. Những gì đề án đạt được	45
8.2. So sánh với phương án thay thế	45
8.3. Hạn chế	46
8.4. Các mối đe dọa đối với tính hợp lệ.....	47
8.5. An toàn và trách nhiệm khi dùng	47
8.6. Bài học rút ra	48
Chương 9. Kết luận và hướng phát triển	49
9.1. Kết luận.....	49
9.2. Hạn chế còn lại	49
9.3. Hướng phát triển.....	50
Tài liệu tham khảo	52
Phụ lục	54
Phụ lục A. Tập PoC mẫu	54
Phụ lục B. Trích báo cáo khuyến nghị mẫu	55
Phụ lục C. Tham chiếu dòng lệnh và biến môi trường.....	56
Phụ lục D. Lược đồ `recommendation.json`	57
Phụ lục E. Danh sách kiểm thử	58
Phụ lục F. Kết quả từng lần chạy	59
Phụ lục G. Cấu trúc thư mục kho	60
Phụ lục H. Bảng thuật ngữ.....	60

DANH MỤC HÌNH

Hình 1. Ba pha PEAK và thành phần hiện thực tương ứng trong hệ thống	5
Hình 2. Kiến trúc tổng thể của hệ thống	13
Hình 3. Luồng xử lý một PoC	14
Hình 4. Xử lý lỗi của lớp LLM.....	16
Hình 5. Cây quyết định của luật khuyến nghị	18

DANH MỤC BẢNG

Bảng 1. Ba loại sản trong PEAK và phạm vi của đồ án	5
Bảng 2. Bốn thành phần của ABLE.....	6
Bảng 3. Từ cơ sở lý thuyết đến quyết định thiết kế.....	8
Bảng 4. Yêu cầu chức năng	11
Bảng 5. Yêu cầu phi chức năng	11
Bảng 6. So sánh các phương án tích hợp	12
Bảng 7. Các trường của Recommendation.....	15
Bảng 8. Luật xác định khuyến nghị và độ tin cậy.....	18
Bảng 9. Các tệp đầu ra của một PoC	20
Bảng 10. Công nghệ sử dụng	21
Bảng 11. Cấu trúc mã nguồn.....	21
Bảng 12. Các chế độ chạy theo cấu hình LLM	29
Bảng 13. Tham chiếu nhanh tùy chọn dòng lệnh	31
Bảng 14. Từ khuyến nghị đến hành động của người sản	31
Bảng 15. Lỗi thường gặp khi viết PoC	33
Bảng 16. Sự cố thường gặp và cách xử lý	33
Bảng 17. Thành phần của CSDL đánh giá.....	35
Bảng 18. Bốn PoC thực nghiệm	35
Bảng 19. Kết quả bốn PoC với mô hình auto	36
Bảng 20. Phạm vi truy vấn và độ phủ của ba PoC riêng (cửa sổ 21/8).....	37
Bảng 21. Dấu hiệu cần tìm có trong dữ liệu không (toàn CSDL 4.417.543 dòng)	38
Bảng 22. Cùng bốn PoC dưới ba cấu hình.....	38
Bảng 23. Số lời gọi và token của judge/advisor	39
Bảng 24. Lỗi phát hiện khi chạy thật và cách xử lý	39
Bảng 25. Kết quả thử một lần các mô hình miễn phí	41
Bảng 26. Đối chiếu yêu cầu và kết quả	42
Bảng 27. So sánh ba cách tiếp cận.....	45
Bảng 28. Các trường của tệp PoC	55
Bảng 29. Biến môi trường	57
Bảng 30. Các khoá cấp cao của recommendation.json	57
Bảng 31. Phân bố 101 bài kiểm thử theo tệp	58
Bảng 32. Tổng hợp các lần chạy cuối (sau khi sửa phạm vi truy vấn) đã dùng trong luận văn	59
Bảng 33. Thuật ngữ và từ viết tắt	60

Chương 1. Mở đầu

1.1. Đặt vấn đề

Các hệ thống phát hiện xâm nhập dựa trên luật và chữ ký chỉ bắt được những gì đã được mô tả trước. Kẻ tấn công có kỹ năng thường đi vòng qua các luật đó bằng công cụ hợp pháp có sẵn trên hệ thống, bằng mã hoá lệnh, hoặc bằng hành vi trông giống quản trị thông thường. Săn mồi đe dọa (threat hunting) bổ sung cho phát hiện tự động bằng cách đặt một giả thuyết về hoạt động của kẻ tấn công rồi chủ động dùng dữ liệu để xác nhận hoặc bác bỏ giả thuyết đó. Hoạt động này phụ thuộc nhiều vào kinh nghiệm của người săn và tốn thời gian ở giai đoạn chuẩn bị: đọc tài liệu về kỹ thuật tấn công, viết giả thuyết kiểm chứng được, xác định nguồn dữ liệu cần dùng, rồi dịch tất cả thành các truy vấn cụ thể.

Khung PEAK (Prepare, Execute, Act with Knowledge) của Splunk SURGe mô tả quy trình đó một cách có cấu trúc [1]. Giai đoạn Prepare của PEAK, gồm chọn chủ đề, nghiên cứu, phát biểu giả thuyết, lập bảng ABLE (Actor, Behavior, Location, Evidence), xác định phạm vi và lập kế hoạch, là phần mà các mô hình ngôn ngữ lớn (LLM) có thể hỗ trợ tốt vì nó chủ yếu là đọc, tổng hợp và viết. Cisco Talos đã công bố mã nguồn mở **PEAK Assistant** [5], một tập tác tử LLM thực hiện đúng các việc đó và xuất ra báo cáo nghiên cứu, bảng ABLE và kế hoạch săn. Chính nhóm tác giả cũng nói rõ đây là bản chứng minh khái niệm, chưa qua kiểm thử bảo mật, nên chỉ phù hợp chạy cục bộ.

Việc dùng LLM trong săn mồi đe dọa đặt ra một vấn đề niềm tin. LLM có thể viết ra những khẳng định nghe hợp lý nhưng không có căn cứ trong dữ liệu [12]. Nếu để LLM vừa lập kế hoạch vừa kết luận, người săn khó phân biệt đâu là điều dữ liệu chứng minh, đâu là điều mô hình suy đoán. Một vấn đề thứ hai tinh tế hơn: khi truy vấn không trả về gì, người dùng và cả mô hình đều dễ diễn giải là "không có tấn công", trong khi nguyên nhân có thể là dữ liệu không được thu thập, cửa sổ thời gian quá hẹp, hoặc vị từ viết sai. Nguyên tắc "không có bằng chứng không đồng nghĩa với bằng chứng không có" [13] vì vậy cần được hiện thực thành quy tắc của hệ thống chứ không chỉ là lời nhắc.

1.2. Bối cảnh và động cơ thực hiện

Kho mã AI_Agent_Hunting ban đầu (phiên bản v6) là một engine điều tra tổng quát xây quanh ba đồ thị: đồ thị khẳng định (ClaimGraph), đồ thị năng lực nhà cung cấp (CapabilityGraph) và đồ thị bằng chứng (EvidenceGraph). Engine có hơn ba mươi sáu nghìn dòng mã nguồn, hàng chục mô-đun và khoảng tám mươi tệp kiểm thử, giải bài toán trả lời câu hỏi điều tra tự do. Qua thực tế sử dụng, phần có giá trị nhất của kho lại là đường chạy PoC: nhận một giả thuyết đã cụ thể hoá, chạy các vị từ trên telemetry, rồi báo cáo. Phần engine lớn gây ba khó khăn: khó đọc và khó bảo trì, khó

giải thích cho người dùng cuối, và trùng lặp với phần Prepare mà PEAK Assistant đã làm tốt hơn.

Động cơ của đề án là tái cấu trúc kho theo hướng: (i) giữ phần thực thi tất định đã được kiểm chứng; (ii) thay phần chuẩn bị tự xây bằng PEAK Assistant; (iii) bổ sung phần còn thiếu nhất là đầu ra có ích cho con người, tức một khuyến nghị có lý do để người sẵn ra quyết định; (iv) làm gọn kho để người mới đọc được trong vài giờ.

1.3. Mục tiêu nghiên cứu

Mục tiêu tổng quát là xây dựng một trợ lý sẵn mỗi đe dọa dùng PEAK Assistant cho pha Prepare, thực thi tất định cho pha Execute, và đưa ra khuyến nghị hỗ trợ quyết định cho pha Act, kiểm chứng trên dữ liệu thật.

Các mục tiêu cụ thể:

- Phân tích và làm gọn kho mã v6, giữ lại đường chạy PoC cùng các adapter telemetry.
- Tích hợp PEAK Assistant qua một lớp cầu nối có khả năng chịu lỗi, dùng chung một cấu hình LLM.
- Thiết kế bộ luật khuyến nghị tất định, có giải thích, không để LLM thay đổi sự thật về bằng chứng.
- Bảo đảm LLM là tùy chọn: không cấu hình LLM thì hệ thống vẫn chạy.
- Chạy bốn PoC có sẵn trên bộ dữ liệu Boss of the SOC v1, ghi nhận kết quả, lỗi và hạn chế một cách trung thực.
- Viết tài liệu hướng dẫn thực hành đủ để một người mới cài đặt, chạy, đọc kết quả và tự viết PoC.

1.4. Đối tượng và phạm vi

Đối tượng nghiên cứu là quy trình sẵn theo giả thuyết (hypothesis-driven hunting) của PEAK, trong đó giả thuyết đã được cụ thể hoá thành PoC. Phạm vi gồm:

- **Trong phạm vi:** pha Prepare qua PEAK Assistant (ABLE, kế hoạch sẵn); pha Execute trên hai loại telemetry là cơ sở dữ liệu SQLite (CDB) và Splunk; pha Act dạng khuyến nghị, bản nháp truy vấn SPL, backlog và ghi chú cho các bên liên quan; kiểm chứng trên Boss of the SOC v1.
- **Ngoài phạm vi:** sẵn theo đường cơ sở (baseline) và sẵn có hỗ trợ mô hình học máy (M-ATH) của PEAK; huấn luyện mô hình; tự động hoá hành động phản ứng sự cố; đánh giá định lượng độ chính xác trên nhiều bộ dữ liệu.
- **Giới hạn đã biết:** bộ dữ liệu có nhãn tấn công hạn chế; adapter Splunk và bản nháp SPL chưa được chạy trên một máy chủ Splunk thật trong đề án này.

1.5. Phương pháp nghiên cứu

Đồ án theo hướng nghiên cứu thiết kế và thực nghiệm. Về lý thuyết, tổng hợp tài liệu về sản phẩm đe dọa, khung PEAK, MITRE ATT&CK, hệ thống đa tác tử dùng LLM và độ tin cậy của LLM. Về thiết kế, xác lập yêu cầu, chọn kiến trúc, và đặt ra các bất biến mà mọi thành phần phải tôn trọng. Về hiện thực, viết mã Python, kiểm thử đơn vị, và tích hợp thư viện PEAK Assistant ở một phiên bản được ghim theo mã băm commit. Về thực nghiệm, chạy hệ thống trên dữ liệu thật, thu thập đầu ra, phân tích từng kết quả và ghi lại mọi lỗi phát sinh. Mọi số liệu trong luận văn lấy từ kết quả chạy lưu trong thư mục `results/` của kho.

1.6. Đóng góp chính

1. Một kiến trúc ghép PEAK Assistant (không tắt định) với bộ thực thi tắt định, trong đó ranh giới tin cậy được ghi rõ và được kiểm thử.
2. Bộ luật khuyến nghị có giải thích, xử lý riêng bốn trường hợp dễ nhầm: chuỗi khớp một phần, kết quả khớp nhưng chưa chứng minh thành công, kết quả rỗng do thiếu dữ liệu, và kết quả rỗng do phạm vi tìm kiếm (host) không có dữ liệu.
3. Cơ chế vận hành LLM thực tế: gọi lại có backoff, quay về chế độ không LLM khi lỗi, chấp nhận nhiều dạng đầu ra JSON, và chế độ hoàn toàn không cần LLM.
4. Làm gọn kho từ khoảng 36.400 dòng xuống khoảng 8.700 dòng mã nguồn mà vẫn giữ khả năng khôi phục engine cũ.
5. Bộ kết quả thực nghiệm và hướng dẫn thực hành có thể tái chạy.

1.7. Bố cục luận văn

Chương 2 trình bày cơ sở lý thuyết. Chương 3 phân tích bài toán và yêu cầu. Chương 4 mô tả thiết kế kiến trúc và bộ luật khuyến nghị. Chương 5 mô tả cài đặt. Chương 6 là hướng dẫn thực hành. Chương 7 trình bày thực nghiệm và đánh giá. Chương 8 thảo luận hạn chế. Chương 9 kết luận và đề xuất hướng phát triển. Phụ lục cung cấp tệp PoC mẫu, báo cáo mẫu, tham chiếu dòng lệnh, cấu hình, danh sách kiểm thử và bảng thuật ngữ.

Chương 2. Cơ sở lý thuyết

Chương này trình bày các khái niệm nền tảng mà hệ thống dựa vào. Mỗi mục kết thúc bằng phần "áp dụng vào đồ án" để người đọc thấy khái niệm đó ảnh hưởng thế nào tới thiết kế ở các chương sau.

2.1. Săn mồi đe dọa

2.1.1. Định nghĩa và vị trí trong vận hành an ninh

Săn mồi đe dọa là hoạt động chủ động, do con người dẫn dắt và có máy hỗ trợ, nhằm tìm ra những hoạt động độc hại đã lọt qua các lớp phát hiện tự động. Điểm xuất phát là giả định đã bị xâm nhập (assume breach): người săn không đợi cảnh báo mà đặt câu hỏi "nếu kẻ tấn công đã ở trong mạng thì dấu vết của chúng trông như thế nào, và dữ liệu nào có thể chứa dấu vết đó". Kết quả của một cuộc săn vì thế không chỉ là nhị phân "có/không tấn công". Nó có thể là: giả thuyết được xác nhận, giả thuyết bị bác bỏ trong phạm vi dữ liệu đã xem, hoặc không kết luận được do dữ liệu không đủ. Một cuộc săn dù không tìm thấy kẻ tấn công vẫn tạo giá trị: phát hiện khoảng trống dữ liệu, sinh ra luật phát hiện mới, hoặc củng cố hiểu biết về môi trường [1].

Trong chu trình xử lý sự cố của NIST [16], săn mồi đe dọa nằm ở phần phát hiện và phân tích, và khi tìm thấy dấu hiệu thật thì chuyển giao cho nhóm ứng cứu sự cố (IR). Điều này giải thích vì sao đầu ra cuối cùng của hệ thống trong đồ án là một khuyến nghị về việc có chuyển giao cho IR hay không, chứ không phải một bản án.

2.1.2. Mô hình trưởng thành của hoạt động săn

Bianco đề xuất Hunting Maturity Model gồm năm mức từ HMM0 đến HMM4: ban đầu (chỉ dựa vào cảnh báo tự động), tối thiểu (có tra cứu chỉ báo), theo quy trình (dùng quy trình do người khác viết), đổi mới (tự tạo quy trình mới) và dẫn đầu (tự động hoá quy trình hiệu quả thành phát hiện) [8]. Mô hình cho thấy một hướng phát triển tự nhiên: các cuộc săn thủ công thành công nên được chuyển thành luật phát hiện tự động. Trong khung PEAK, bước đó gắn với pha Act.

2.1.3. Kim tự tháp đau đớn và hành vi

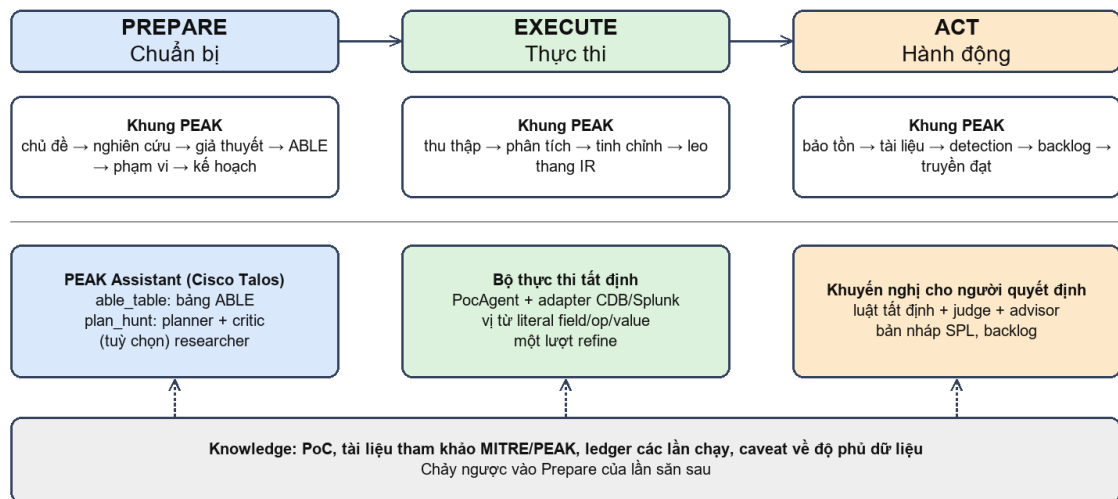
Kim tự tháp đau đớn (Pyramid of Pain) xếp các loại chỉ báo theo mức khó khăn mà kẻ tấn công phải chịu khi bị buộc đổi chúng: giá trị băm, địa chỉ IP, tên miền, dấu vết mạng và máy, công cụ, và cuối cùng là chiến thuật, kỹ thuật, quy trình (TTP) [7]. Săn theo hành vi nằm ở đỉnh tháp vì kẻ tấn công khó đổi hành vi hơn là đổi một địa chỉ IP. Đồ án thể hiện điều này trong các PoC: PoC khai thác Joomla và PoC mã hoá PowerShell là chỉ báo hành vi, còn PoC beacon tới `ad.networkfilter.co` là chỉ báo ở mức tên miền, vốn dễ bị thay đổi.

2.2. Khung PEAK

2.2.1. Ba pha và yếu tố tri thức

PEAK do nhóm Splunk SURGe (trong đó có David Bianco, người sau này cũng là tác giả chính của PEAK Assistant) giới thiệu năm 2023 [1]. Tên gọi là chữ viết tắt của ba pha cộng một yếu tố xuyên suốt:

- **Prepare:** chọn chủ đề, nghiên cứu, phát biểu giả thuyết, xác định phạm vi và dữ liệu cần dùng, lập kế hoạch.
- **Execute:** thu thập dữ liệu, xử lý sơ bộ, phân tích, tinh chỉnh giả thuyết, và leo thang khi có phát hiện nghiêm trọng.
- **Act:** bảo tồn kết quả, ghi tài liệu, tạo luật phát hiện, đưa việc còn lại vào backlog và truyền đạt cho các bên liên quan.
- **Knowledge:** threat intelligence, ngữ cảnh của tổ chức, kinh nghiệm người sẵn và chính kết quả các cuộc sẵn trước, chảy vào cả ba pha.



Hình 1. Ba pha PEAK và thành phần hiện thực tương ứng trong hệ thống

PEAK là quy trình dành cho nhà phân tích con người chứ không phải đặc tả phần mềm. Vì vậy, hệ thống trong đồ án không tự nhận là "hiện thực PEAK được chứng nhận". Nó chỉ hiện thực hoá ba pha theo hướng hỗ trợ: PEAK Assistant làm Prepare, bộ thực thi tắt định làm Execute, và mô-đun khuyến nghị làm Act.

2.2.2. Ba loại sẵn của PEAK

PEAK định nghĩa ba loại sẵn, cùng đi qua ba pha trên [2][3][4].

Bảng 1. Ba loại sẵn trong PEAK và phạm vi của đồ án

Loại	Mục đích	Cách làm	Trong đồ án
Hypothesis-driven	Kiểm chứng một giả	Chọn chủ đề, làm cho	Có (đối tượng chính)

Loại	Mục đích	Cách làm	Trong đồ án
	thuyết về hành vi kẻ tấn công	kiểm chứng được, tinh chỉnh cho đủ cụ thể, rồi truy vấn dữ liệu	
Baseline	Mô tả "bình thường" để nhìn ra độ lệch	Từ điển dữ liệu, phân bố, ngoại lệ, khoảng trống; khuyến nghị cửa sổ 30–90 ngày	Không (ngoài phạm vi)
M-ATH (Model-Assisted)	Dùng thuật toán tìm đầu mỗi khi cách đơn giản không đủ	Phân loại, phân cụm, phát hiện bất thường, có người trong vòng lặp	Không (ngoài phạm vi)

2.2.3. Mô hình ABLE

ABLE là cách PEAK biến một giả thuyết thành kế hoạch hành động. Mỗi chữ cái là một câu hỏi người sẵn phải trả lời:

Bảng 2. Bốn thành phần của ABLE

Thành phần	Câu hỏi	Ví dụ (rò rỉ dữ liệu qua DNS)
Actor	Ai thực hiện (được phép để trống)	Chưa rõ nhóm cụ thể
Behavior	Hành vi cụ thể, nên chỉ 1–2 kỹ thuật	DNS tunneling
Location	Hành vi xảy ra ở phần nào của mạng	Máy trạm phòng tài chính và biên mạng
Evidence	Cần nguồn dữ liệu nào, và dấu hiệu trùng trông ra sao	Nhật ký DNS: truy vấn dài, loại bản ghi lạ

ABLE đóng vai trò cầu nối giữa phát biểu giả thuyết bằng văn xuôi và truy vấn cụ thể. PEAK Assistant có một tác tử riêng sinh bảng ABLE từ giả thuyết, tài liệu nghiên cứu và mô tả dữ liệu cục bộ [5]. Trong đồ án, bảng ABLE do PEAK sinh ra là thông tin tham khảo cho người sẵn, còn các vị từ thực thi do PoC khai báo.

2.3. MITRE ATT&CK và chỉ báo thực thi

MITRE ATT&CK là cơ sở tri thức về chiến thuật và kỹ thuật của kẻ tấn công dựa trên quan sát thực tế [6]. Mỗi kỹ thuật có mã định danh, ví dụ T1190 (khai thác ứng dụng hướng ra Internet), T1110 (dò mật khẩu), T1059.001 (PowerShell), T1071.001 (giao thức tầng ứng dụng: web). Mã này giúp người sẵn tìm tài liệu nghiên cứu và đặt tên kết quả theo ngôn ngữ chung. Trong các PoC của đồ án, mỗi PoC gắn một kỹ thuật ATT&CK trong trường references và able.behavior.

2.4. Mô hình ngôn ngữ lớn và hệ thống đa tác tử

2.4.1. LLM như một thành phần tạo văn bản

LLM sinh văn bản bằng cách dự đoán chuỗi token tiếp theo. Chúng mạnh ở các việc như tóm tắt tài liệu, diễn đạt lại, chuyển tài liệu thành cấu trúc, và gợi ý bước tiếp theo. Chúng yếu ở những việc đòi hỏi tính đúng đắn tuyệt đối trên dữ liệu cụ thể, vì không có cơ chế nội tại để đối chiếu mỗi câu với nguồn. Hiện tượng sinh ra thông tin nghe hợp lý nhưng sai hoặc không có căn cứ được gọi là ảo giác (hallucination) [12]. Truy hồi tăng cường (retrieval-augmented generation) giảm rủi ro này bằng cách đưa tài liệu nguồn vào ngữ cảnh [14]; tuy nhiên nó không loại bỏ hoàn toàn, vì mô hình vẫn có thể diễn giải sai tài liệu được cung cấp.

2.4.2. Tác tử và đa tác tử

Một tác tử LLM là một vòng lặp trong đó mô hình quyết định hành động tiếp theo, quan sát kết quả và tiếp tục; ReAct là một mô hình điển hình kết hợp suy luận và hành động [10]. Hệ thống đa tác tử cho nhiều tác tử với vai trò khác nhau trao đổi với nhau. AutoGen là một khung phổ biến cho kiểu này, hỗ trợ các nhóm tác tử trò chuyện theo lượt và điều kiện dừng [9]. PEAK Assistant dùng AutoGen: nhóm lập kế hoạch có một tác tử viết kế hoạch và một tác tử phê bình, luân phiên cho tới khi tác tử phê bình trả về tín hiệu kết thúc [5]. Mô hình "người viết và người phản biện" này thường cải thiện chất lượng văn bản, nhưng cũng làm số lượt gọi LLM không cố định trước, và khó kiểm soát chi phí.

2.4.3. LLM làm giám khảo

Dùng LLM để chấm hoặc đánh giá đầu ra (LLM-as-a-judge) được nghiên cứu rộng rãi và cho thấy mức đồng thuận với người đánh giá khá cao trên một số tác vụ, nhưng cũng có thiên lệch và không ổn định giữa các lần chạy [11]. Vì vậy trong đồ án, "judge" chỉ được dùng như ý kiến tham khảo thứ hai: nó nhận hàng bằng chứng đã được bộ thực thi lấy ra và trả lời một trong bốn nhãn (TRUE_POSITIVE, FALSE_POSITIVE, INCONCLUSIVE, NO_SIGNAL) kèm độ tin cậy. Luật khuyến nghị tất định luôn là bên quyết định, và judge chỉ có thể đẩy kết quả đi tới đa một bậc.

2.5. Độ tin cậy của bằng chứng và bằng chứng âm tính

2.5.1. Vắng bằng chứng không phải bằng chứng vắng mặt

Altman và Bland nhấn mạnh rằng một nghiên cứu không tìm thấy hiệu ứng chưa chứng minh hiệu ứng không tồn tại [13]. Trong sản phẩm đe dọa, điều tương đương là một truy vấn rỗng. Có ít nhất bốn nguyên nhân khiến truy vấn rỗng mà vẫn có tấn công: nguồn dữ liệu không được thu thập; nguồn có nhưng không chứa loại sự kiện cần tìm; cửa sổ thời gian không bao trùm hoạt động; và vị từ literal bỏ sót biến thể. Hệ

thống trong đồ án không xử lý hết được cả bốn, nhưng hiện thực hoá ba (độ phủ nguồn trong cửa sổ; độ phủ trong phạm vi host kèm chạy lại không lọc host; giới hạn cửa sổ) và nêu rõ, kèm liệt kê loại sự kiện thực có, điểm còn lại trong phần "giới hạn của kết luận" của mỗi báo cáo.

2.5.2. Tách bạch bằng chứng và diễn giải

Nguyên tắc thiết kế chung của đồ án là hai lớp. Lớp bằng chứng chỉ gồm các bản ghi do adapter trả về từ telemetry, có thể tái lập. Lớp diễn giải gồm mọi văn bản do LLM sinh ra (ABLE, kế hoạch, judge, advisor), luôn được gắn nhãn là tham khảo. Bản ghi không bao giờ đi từ lớp diễn giải sang lớp bằng chứng. Nguyên tắc này đối ứng với khuyến nghị của OWASP về ứng dụng dùng LLM: không tin tưởng đầu ra của mô hình như dữ liệu đã xác thực và không giao cho mô hình quyền thực thi không kiểm soát [17].

2.6. Hỗ trợ ra quyết định

Hệ thống hỗ trợ ra quyết định khác hệ thống ra quyết định tự động ở chỗ nó đưa phương án, lý do và rủi ro, còn quyền chọn thuộc về người dùng. Một khuyến nghị tốt cho người sẵn cần: nêu rõ kết luận và mức độ tin cậy; liệt kê các lựa chọn theo thứ tự ưu tiên; chỉ ra bằng chứng nào ủng hộ và điều gì còn chưa biết; nêu hậu quả của việc chọn sai. Đồ án chuyển các yêu cầu này thành cấu trúc dữ liệu Recommendation với các trường disposition, confidence, reasons, caveats, options, next_steps, questions_for_hunter, risks và cờ decision_required luôn bằng đúng.

2.7. Telemetry và bộ dữ liệu Boss of the SOC v1

Telemetry là dữ liệu quan sát được từ hệ thống: tạo tiến trình (sự kiện 4688 của Windows hoặc sự kiện 1 của Sysmon), xác thực (4624 đăng nhập thành công, 4625 đăng nhập thất bại), truy cập chia sẻ SMB (5140, 5145), truy vấn DNS và yêu cầu web. Mỗi nguồn trả lời được một lớp câu hỏi, và không nguồn nào trả lời được tất cả. Ví dụ, yêu cầu web chứa trong dữ liệu của đồ án chỉ có tên miền và đường dẫn, không có mã trạng thái, nên không đủ để chứng minh một cuộc khai thác thành công.

Boss of the SOC (BOTS) v1 là bộ dữ liệu do Splunk công bố cho các cuộc thi và huấn luyện an ninh, chứa nhật ký từ một môi trường mô phỏng bị tấn công trong tháng 8 năm 2016, bao gồm cả giai đoạn quét và khai thác một máy chủ Joomla [15]. Trong đồ án, dữ liệu được nạp vào một bảng SQLite events gồm 4.417.543 dòng trải trên 28 ngày.

2.8. Tổng hợp: từ lý thuyết đến quyết định thiết kế

Bảng 3. Từ cơ sở lý thuyết đến quyết định thiết kế

Cơ sở lý thuyết	Hệ quả thiết kế
-----------------	-----------------

Cơ sở lý thuyết	Hệ quả thiết kế
PEAK có ba pha, Prepare tốn công và hợp với LLM	PEAK Assistant đảm nhiệm Prepare; Execute và Act tách riêng
ABLE nối giả thuyết với truy vấn	Bảng ABLE do PEAK sinh là đầu vào cho kế hoạch và cho advisor
LLM có thể ảo giác [12]	LLM không bao giờ tạo hoặc sửa bản ghi bằng chứng
LLM-as-judge không ổn định [11]	Judge chỉ tham khảo, chỉ đẩy khuyến nghị tối đa một bậc
Vắng bằng chứng không phải bằng chứng vắng [13]	Kiểm tra độ phủ nguồn; rộng + thiếu nguồn thành COLLECT_DATA_THEN_RERUN
Khuyến nghị cần lý do và rủi ro	Cấu trúc Recommendation đầy đủ và cờ decision_required
Đa tác tử khó dự đoán số lượt gọi [9]	Giới hạn thời gian từng bước, gọi lại có backoff, quay về kế hoạch của PoC

Chương 3. Phân tích bài toán và yêu cầu hệ thống

3.1. Hiện trạng kho mã v6

Trước khi tái cấu trúc, kho `AI_Agent_Hunting` có hai đường chạy độc lập. Đường thứ nhất là engine giả thuyết tự do: người dùng gõ một câu hỏi hoặc một mã CVE/TTP, một LLM biên dịch thành đề thi khẳng định, engine chọn nhà cung cấp dữ liệu qua đề thi năng lực, thực thi truy vấn, xác minh quan hệ và dựng đề thi bằng chứng. Đường thứ hai là đường PoC: người dùng viết một PoC dạng JSON gồm vài vị từ cụ thể, tác tử PoC chạy từng vị từ qua adapter, rồi một bước judge tùy chọn đánh giá kết quả.

Kiểm kê cho thấy các điểm sau:

- Tổng mã nguồn `src/` khoảng 36.400 dòng; riêng tệp `engine.py` hơn 3.300 dòng, `cli.py` hơn 1.700 dòng.
- Đường PoC chỉ phụ thuộc vào khoảng 7.200 dòng (gồm hai adapter, các hợp đồng dữ liệu mà adapter cần, và mô-đun `Act`). Phần còn lại phục vụ riêng engine giả thuyết tự do.
- Phần "Prepare" của PEAK đã được tự xây (`peak.py`: công kiểm tra trường bắt buộc, trình hướng dẫn nhập, đọc kế hoạch YAML). Nó kiểm tra việc có điền đủ trường, nhưng không giúp người dùng viết ra nội dung tốt.
- Kết quả cuối của đường PoC là một nhãn (`MATCHED/EMPTY`) kèm một nhận định judge. Người sản phải tự suy ra nên làm gì tiếp.

3.2. Vấn đề cần giải quyết

Từ hiện trạng, đề án tập trung vào bốn vấn đề.

Vấn đề 1: độ phức tạp vượt nhu cầu. Phần lớn người dùng cần chạy một giả thuyết đã cụ thể hoá và nhận kết quả dễ hiểu, không cần một engine suy diễn tổng quát. Độ phức tạp thừa làm tăng chi phí bảo trì và rào cản học.

Vấn đề 2: chuẩn bị sẵn đang là việc thủ công. Viết bảng ABLE, xác định nguồn dữ liệu và lập kế hoạch cần đọc tài liệu và viết nhiều văn bản. PEAK Assistant tự động hoá chính các việc này, nên việc tiếp tục tự xây là lãng phí.

Vấn đề 3: đầu ra chưa phục vụ quyết định. "MATCHED, 200 bản ghi" chưa cho người sản biết có nên chuyển cho IR hay không, độ tin cậy ra sao, và còn thiếu gì. Một cuộc sản rộng còn tệ hơn: nhãn "EMPTY" dễ bị đọc nhầm thành "an toàn".

Vấn đề 4: ràng buộc vận hành LLM. Endpoint LLM có thể không sẵn sàng, bị giới hạn tốc độ, trả lỗi thoáng qua hoặc tốn phí. Người dùng có thể chưa có khoá API. Hệ thống không được sập hay trả kết quả sai trong những tình huống đó.

3.3. Yêu cầu chức năng

Bảng 4. Yêu cầu chức năng

Mã	Yêu cầu	Căn cứ
FR1	Nạp PoC từ tệp JSON, kiểm tra các trường Prepare bắt buộc	Vấn đề 2
FR2	Gọi PEAK Assistant sinh bảng ABLE và kế hoạch sẵn cho mỗi PoC	Vấn đề 2
FR3	Thực thi các vị từ literal trên telemetry qua adapter (CDB, Splunk)	Giữ giá trị đường PoC
FR4	Kiểm tra độ phủ của từng nguồn dữ liệu trong cửa sổ thời gian	Vấn đề 3
FR5	Sinh khuyến nghị xếp hạng với lý do, giới hạn, câu hỏi, rủi ro	Vấn đề 3
FR6	Chạy được nhiều PoC một lần và tổng hợp bảng kết quả	Vấn đề 1
FR7	Xuất báo cáo Markdown và JSON, bản nháp SPL, backlog	Pha Act của PEAK
FR8	Chạy được hoàn toàn không có LLM	Vấn đề 4
FR9	Chọn được mô hình LLM từ dòng lệnh	Vấn đề 4

3.4. Yêu cầu phi chức năng

Bảng 5. Yêu cầu phi chức năng

Mã	Yêu cầu	Cách kiểm chứng
NFR1	LLM không tạo hoặc sửa bản ghi bằng chứng	Mọi hàng đều đến từ adapter; có kiểm thử
NFR2	Kết quả phân tích định tái lập được	Cùng PoC và cùng dữ liệu cho cùng số bản ghi
NFR3	Lỗi LLM không làm sập pipeline	Kiểm thử mô phỏng lỗi; chạy thật gặp lỗi 404
NFR4	Không ghi khoá API ra đĩa hay báo cáo	Cấu hình PEAK chỉ chứa <code>ENV</code> ; quét kết quả không thấy khoá
NFR5	Hệ thống nhỏ, đọc được	Mã nguồn dưới 10.000 dòng
NFR6	Khôi phục được engine cũ	Gắn thẻ git <code>v6-engine-final</code>
NFR7	Python 3.12 trở lên	Yêu cầu của PEAK Assistant

3.5. Các phương án thiết kế

Ba phương án được cân nhắc cho việc dùng PEAK Assistant.

Phương án A: dùng PEAK Assistant nguyên bản qua giao diện Streamlit. Ưu điểm là không viết mã. Nhược điểm: hoàn toàn thủ công, không chạy được hàng loạt, không có bước thực thi trên telemetry của kho, không có khuyến nghị cuối. Phương án này chỉ cho phần Prepare.

Phương án B: gọi PEAK Assistant qua máy chủ MCP của nó ('peak-mcp'). Hợp với việc để một tác tử LLM khác điều phối. Nhược điểm: thêm một tầng giao thức và một tiến trình máy chủ, khó kiểm thử và khó chịu lỗi; điều phối bởi LLM đi ngược với yêu cầu phần Execute tất định.

Phương án C (được chọn): dùng PEAK Assistant như thư viện Python. Các hàm `able_table`, `plan_hunt` (và tùy chọn `researcher`) là hàm bất đồng bộ nhận chuỗi và trả chuỗi, nên đóng gói thành một lớp cầu nối mỏng trong tiến trình của hệ thống. Ưu điểm: tích hợp chặt, dễ chịu lỗi, dễ kiểm thử bằng cách giả lập lớp cầu nối. Nhược điểm: phụ thuộc vào API nội bộ của một dự án chứng minh khái niệm, nên cần ghim phiên bản theo mã băm commit (`dfabbb0`).

Bảng 6. So sánh các phương án tích hợp

Tiêu chí	A: Streamlit	B: MCP	C: thư viện
Chạy hàng loạt	Không	Có	Có
Thực thi tất định tách khỏi LLM	Không áp dụng	Khó	Dễ
Kiểm thử tự động	Khó	Khó	Dễ
Độ phức tạp thêm	Thấp	Cao	Trung bình
Rủi ro thay đổi API	Thấp	Trung bình	Cao (giảm bằng ghim phiên bản)

3.6. Các bất biến thiết kế

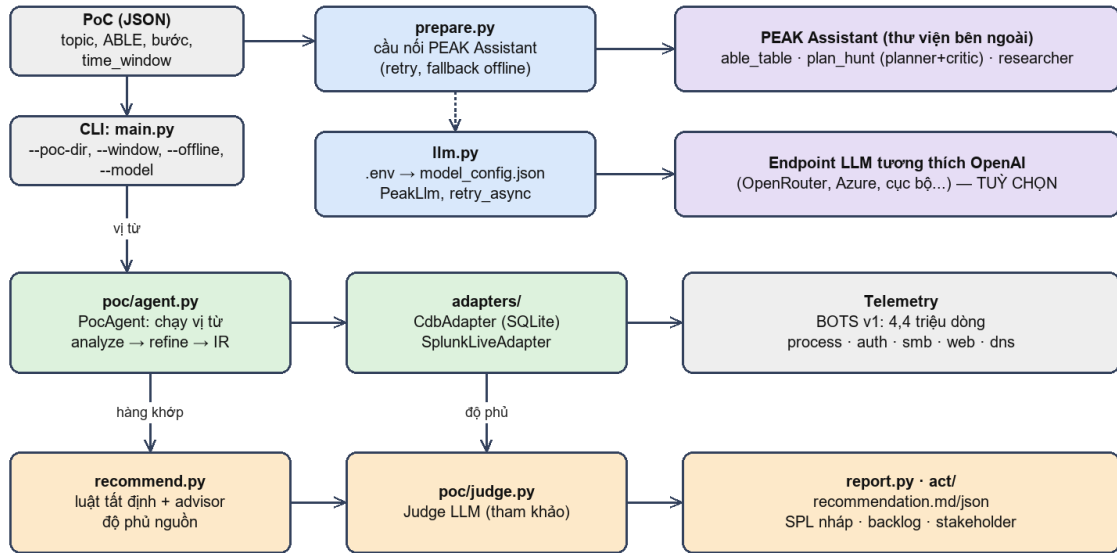
Từ vấn đề và yêu cầu, năm bất biến được đặt ra và áp dụng cho mọi thành phần mới.

- LLM không tạo bằng chứng.** Mọi bản ghi bằng chứng đến từ adapter. Văn bản của LLM chỉ xuất hiện ở các mục được gắn nhãn tham khảo.
- Khớp là literal và tái lập.** Cùng PoC, cùng dữ liệu cho cùng kết quả.
- Vắng dữ liệu không thành "sạch".** Nguồn có 0 bản ghi trong cửa sổ cho `COLLECT_DATA_THEN_RERUN`; kết quả rỗng khi nguồn có dữ liệu vẫn kèm cảnh báo về giới hạn.
- Người quyết định cuối cùng.** Mọi khuyến nghị có `decision_required = true`; hệ thống không thực hiện hành động phản ứng.
- LLM là tùy chọn.** Mọi chức năng cốt lõi chạy được khi không có LLM; LLM chỉ làm giàu thêm.

Chương 4. Thiết kế hệ thống

4.1. Tổng quan kiến trúc

Hệ thống gồm ba nhóm thành phần ứng với ba pha PEAK, cộng một lớp hạ tầng LLM dùng chung. Hình 2 trình bày các mô-đun và luồng dữ liệu chính.

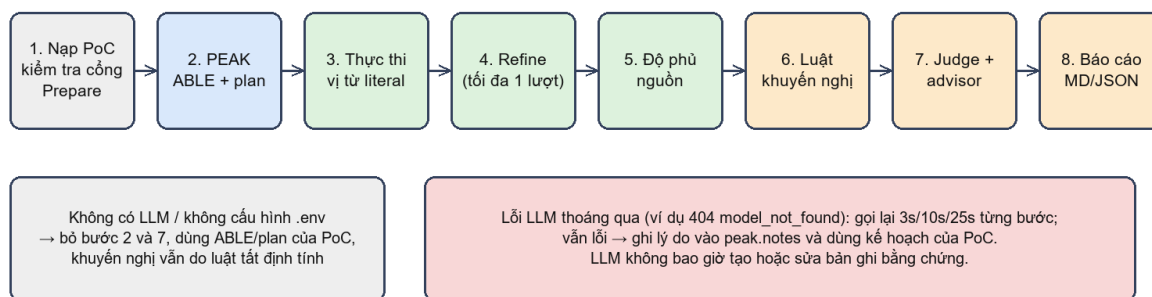


Hình 2. Kiến trúc tổng thể của hệ thống

- **Nhóm Prepare** (prepare.py, llm.py): gọi PEAK Assistant để sinh bảng ABLE và kế hoạch sẵn. Đây là nơi duy nhất mã của hệ thống gọi vào thư viện PEAK Assistant.
- **Nhóm Execute** (poc/, adapters/): nạp PoC, chạy các vị từ literal qua adapter, tinh chỉnh tối đa một lượt, ghi sổ cái (ledger). Không có LLM trong việc khớp bản ghi.
- **Nhóm Act** (recommend.py, poc/judge.py, report.py, act/): tính độ phủ nguồn, sinh khuyến nghị bằng luật tắt định, hỏi judge và advisor (tùy chọn), xuất báo cáo, bản nháp SPL, backlog và ghi chú cho các bên liên quan.
- **Lớp LLM dùng chung** (llm.py): biến cấu hình trong .env thành cấu hình mô hình của PEAK, và cung cấp một bộ gọi đồng bộ cho judge và advisor, để mọi lần gọi đều đi qua cùng một đường và cùng một chính sách gọi lại.

4.2. Luồng xử lý một PoC

Hình 3 trình bày luồng tám bước khi chạy một PoC. Các bước 2 và 7 là các bước có LLM; khi không có LLM, chúng được bỏ qua và phần còn lại không đổi.



Hình 3. Luồng xử lý một PoC

1. **Nạp PoC và kiểm tra cổng Prepare.** PoC phải có chủ đề, hành vi, vị trí, bằng chứng, phạm vi, thời lượng tối đa, kế hoạch và tài liệu nghiên cứu (trường actor được để trống). Thiếu một trường thì PoC bị từ chối trước khi chạm vào telemetry.
2. **PEAK Prepare.** Dựng đầu vào cho PEAK từ PoC và từ mô tả telemetry của adapter, gọi `able_table` rồi `plan_hunt`.
3. **Thực thi vị từ.** Mỗi bước của PoC được thực hiện qua adapter bằng phép tìm văn bản thô (quét tối đa 2.000 hàng), rồi bộ lọc đúng toán tử được áp dụng lên trường đích; tối đa 100 hàng được giữ làm bằng chứng và tổng số hàng khớp được ghi lại. Ngoài vị từ, truy vấn còn chịu phạm vi suy ra từ ABLE của PoC (host từ `able.location`, các chuỗi cụ thể từ `able.behavior` và `able.evidence`); phạm vi này được hiển thị trong báo cáo.
4. **Tinh chỉnh.** Tối đa một lượt: nếu mọi hit đến từ đúng một máy thì chạy lại các bước còn lại trên máy đó; nếu rỗng thì chạy lại đúng các vị từ gốc. Toán tử không bao giờ bị nói (EQUALS không thành CONTAINS).
5. **Độ phủ nguồn.** Với mỗi `source_kind` của các bước, đếm số bản ghi của nguồn đó trong cửa sổ và trong phạm vi host của PoC, đồng thời liệt kê các loại sự kiện thực có. Nếu nguồn có dữ liệu nhưng không có bản ghi nào trong phạm vi host, hệ thống chạy lại PoC một lần không lọc host (thư mục `unscoped_probe/`) để phân biệt "host này không ghi nguồn" với "không có hoạt động ở đâu cả".
6. **Luật khuyến nghị.** Tính disposition và confidence từ bằng chứng, độ phủ và nhận định judge.
7. **Judge và advisor.** Judge chỉ chạy khi có bản ghi khớp. Advisor luôn chạy nếu có LLM, nhận kế hoạch PEAK và tóm tắt bằng chứng, và trả về bước tiếp theo, câu hỏi và rủi ro.
8. **Báo cáo.** Ghi `recommendation.md`, `recommendation.json`, bản nháp SPL và các tệp phụ.

4.3. Mô hình dữ liệu

4.3.1. PoC

PoC là cấu trúc bất biến gồm hai phần. Phần Prepare: topic, actor, behavior, location, evidence, research_refs, scope, max_duration, plan. Phần thực thi: danh sách steps (mỗi bước có step_id, description, target_field, op, value, source_kind), danh sách fallbacks, references và expected_chain. Hệ thống bổ sung time_window làm cửa sổ mặc định.

Sáu toán tử được hỗ trợ: EQUALS, CONTAINS, STARTS_WITH, ENDS_WITH, MATCHES (biểu thức chính quy) và EXISTS. Bốn toán tử đầu so sánh không phân biệt hoa thường; EQUALS còn khớp theo tên tệp cuối đường dẫn (ví dụ C:\Windows\...\powershell.exe khớp powershell.exe) nhưng không khớp splunk-powershell.exe.

4.3.2. Kết quả thực thi và bằng chứng

PocHuntResult giữ danh sách StepResult (số hàng và các hàng của từng bước), danh sách bước đã khớp, nhận định judge (nếu có), nhật ký tinh chỉnh và đường dẫn sổ cái. EvidenceSummary là bản tóm tắt phục vụ khuyến nghị: với mỗi bước có số hàng khớp và số bản ghi nguồn trong cửa sổ; ngoài ra có thời điểm đầu và cuối của hit, các giá trị xoay trục hàng đầu (máy, người dùng, IP, tên miền), giá trị phổ biến của các trường đích và tối đa năm hàng mẫu. EvidenceSummary còn mang phạm vi truy vấn thực tế (scope), số bản ghi khớp tổng và cờ bị cắt của từng bước, cơ cấu loại sự kiện của nguồn, các host thực sự ghi nguồn khi phạm vi host rộng, và kết quả chạy lại không lọc host (unscoped_probe).

4.3.3. Khuyến nghị

Recommendation là đầu ra cuối. Các trường chính và ý nghĩa:

Bảng 7. Các trường của Recommendation

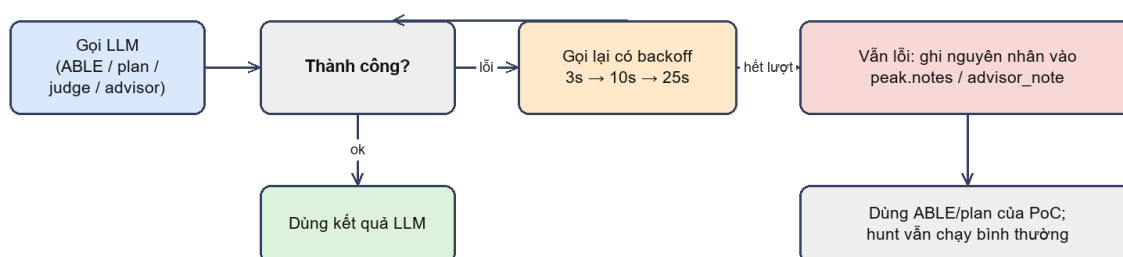
Trường	Ý nghĩa
disposition	Một trong năm giá trị: ESCALATE_TO_IR, INVESTIGATE_FURTHER, TUNE_POC_OR_CLOSE, COLLECT_DATA_THEN_RERUN, CLOSE_WITH_CAVEAT
confidence	HIGH, MEDIUM hoặc LOW
reasons	Các lý do tắt định dẫn tới kết luận
caveats	Giới hạn của kết luận (độ phù, biến thể, cửa sổ, thành công chưa chứng minh)
options	Các lựa chọn xếp hạng cho người quyết định, mỗi lựa chọn có việc cần làm
judge	Nhận định tham khảo của LLM (nếu có)
next_steps, questions_for_hunter, risks	Phần advisor tạo, tối đa năm mục mỗi loại
decision_required	Luôn bằng đúng

4.4. Lớp cầu nối PEAK Assistant

PEAK Assistant cung cấp các hàm bất đồng bộ độc lập, nên lớp cầu nối chỉ cần dựng đúng đầu vào, gọi, kiểm tra đầu ra và xử lý lỗi. Đầu vào được dựng như sau:

- **Giả thuyết:** tên PoC ghép với phần tóm tắt.
- **Tài liệu nghiên cứu:** dựng từ chủ đề, tài liệu tham khảo, tham chiếu MITRE, chuỗi quan sát kỳ vọng và các vị từ do nhà phân tích viết. Với tùy chọn `--research`, tác tử `researcher` của PEAK được dùng thay thế (cần máy chủ MCP nghiên cứu).
- **Tài liệu dữ liệu cục bộ và khám phá dữ liệu:** mô tả do adapter sinh ra (`describe_data`): tên bảng, các cột, các loại sự kiện, số dòng và khoảng thời gian của từng loại. Trong cài đặt gốc của PEAK, tài liệu này đến từ bước khám phá dữ liệu qua máy chủ MCP của Splunk; đồ án thay bằng mô tả trực tiếp từ adapter.
- **Ngữ cảnh cục bộ:** một đoạn văn bản cố định nói rõ rằng hunt chạy bằng bộ thực thi tất định, mỗi bước là một vị từ literal, các toán tử và quy tắc phân biệt hoa thường, LLM không tạo bằng chứng, và kế hoạch phải nói rõ chỗ nào dữ liệu hiện có không trả lời được. Ngữ cảnh này làm cho kế hoạch do PEAK viết bám vào năng lực thật của hệ thống thay vì giả định một Splunk đầy đủ.

Hình 4 mô tả chính sách lỗi. Mỗi bước (ABLE, kế hoạch) được gọi lại tối đa ba lần với khoảng chờ 3, 10 và 25 giây. Nếu cả cuộc Prepare thất bại, thử lại một lần nữa toàn bộ. Nếu vẫn thất bại, hệ thống dùng bảng ABLE và kế hoạch dựng từ chính PoC, ghi nguyên nhân vào `peak.notes` và đánh dấu `used_peak = false`. Việc săn không bị gián đoạn.



Hình 4. Xử lý lỗi của lớp LLM

4.5. Bộ thực thi và adapter

4.5.1. Khớp hai tầng

Adapter CDB thực hiện phép tìm văn bản thô: mỗi giá trị tìm kiếm được so khớp bằng LIKE trên các cột văn bản (`raw_ref`, `cmdline`, `image`, `file_path`, `domain`, `user`, `host`, `native_type`) với tham số hoá an toàn. Phép tìm này có chủ ý rộng để không bỏ

sót. Sau đó bộ thực thi áp dụng toán tử thật của bước lên đúng trường đích. Thiết kế hai tầng này sinh ra từ một lỗi thực tế: khi chỉ dùng LIKE, vị từ image EQUALS powershell.exe khớp luôn cả splunk-powershell.exe và tạo 100 báo động giả trên 4,38 triệu dòng; bộ lọc chính xác ở tầng hai đưa tỷ lệ này về không.

Giới hạn hàng và quét. Nếu adapter chỉ trả 100 hàng rồi mới lọc, các hàng khớp đúng có thể nằm ngoài 100 hàng đầu và bị bỏ sót; một kiểm tra thực tế cho thấy bước EQUALS của PoC Joomla chỉ còn 99 hàng vì một hàng trong 100 hàng đầu bị bộ lọc loại, trong khi tổng số khớp thật lớn hơn nhiều. Vì vậy mỗi bước quét tối đa SCAN_LIMIT = 2000 hàng, áp dụng toán tử, rồi giữ ROW_CAP = 100 hàng đầu làm bằng chứng và lưu matched_total. Cờ scan_truncated cho biết lượt quét chạm giới hạn, nghĩa là tổng chỉ là cận dưới (báo cáo ghi ≥).

Hai toán tử cần xử lý riêng ở tầng truy xuất. MATCHES không thể đưa nguyên biểu thức chính quy vào LIKE (dấu . hay \d sẽ không khớp gì); hệ thống chỉ dùng đoạn literal bắt buộc dài nhất của biểu thức (ví dụ acunet cho acunet.x-\d+) để thu hẹp, và bỏ thu hẹp nếu biểu thức có phép chọn |. EXISTS được đẩy xuống SQL thành điều kiện "trường khác rỗng" để giới hạn hàng không che mất kết quả.

4.5.2. Độ phủ nguồn

Mỗi bước khai báo source_kind (process, web, dns, authentication, file, smb). Adapter ánh xạ loại nguồn sang các giá trị native_type tương ứng và có ba truy vấn có tham số: đếm bản ghi trong cửa sổ (tuỳ chọn theo host), liệt kê loại sự kiện native_type/event_id kèm số lượng, và liệt kê các host thực sự ghi nguồn. Nếu adapter không có các phương thức này (như adapter Splunk hiện tại), độ phủ được ghi là "không kiểm tra được", và luật khuyến nghị hạ độ tin cậy tương ứng.

Phạm vi host ngầm. Hàm able_drive suy ra một host từ able.location (token đầu tiên trông giống tên máy, ví dụ we1149srv), một tài khoản từ able.actor và các literal cụ thể từ able.behavior/able.evidence; chúng được thêm vào mọi bước. Đây là hành vi có chủ ý của thiết kế Execute từ phiên bản trước nhưng không hiển thị trong predicate, nên đồ án bổ sung ba biện pháp: (i) báo cáo ghi rõ phạm vi thực tế; (ii) độ phủ được đếm cả trong phạm vi host; (iii) khi phạm vi host không có dữ liệu mà cửa sổ có, hệ thống chạy lại không lọc host. Lý do cần cả ba được nêu ở mục 7.2.2: trong dữ liệu thực nghiệm, máy được nêu trong location của cả ba PoC rỗng không ghi nguồn tương ứng, nên các PoC này chưa từng thực sự tìm kiếm trên dữ liệu nào.

4.5.3. Giới hạn cửa sổ và thời lượng

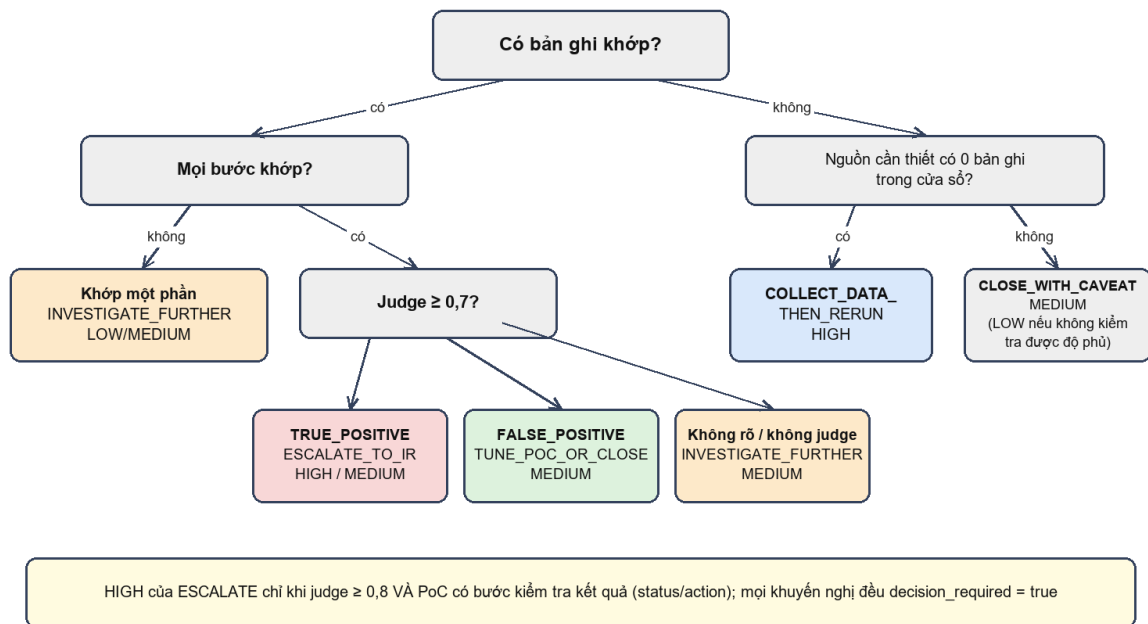
Trường max_duration làm hai việc: cắt cửa sổ telemetry dài hơn thời lượng này về phần cuối, và đặt hạn cho lượt tinh chỉnh. Cửa sổ cụ thể lấy từ --window hoặc từ time_window của PoC.

4.6. Bộ luật khuyến nghị

4.6.1. Các disposition

- **ESCALATE_TO_IR**: chuỗi khớp đủ và judge nhận định có dấu hiệu độc hại với độ tin cậy từ 0,7.
- **INVESTIGATE_FURTHER**: có bản ghi khớp nhưng chuỗi chưa đủ, hoặc ngữ cảnh chưa chứng minh.
- **TUNE_POC_OR_CLOSE**: chuỗi khớp đủ nhưng judge thấy hoạt động hợp lệ; nên thêm điều kiện loại trừ hoặc đóng.
- **COLLECT_DATA_THEN_RERUN**: không có hit và có nguồn cần thiết với 0 bản ghi trong cửa sổ (hoặc 0 bản ghi trong phạm vi host mà không có lần chạy lại không lọc host); không có dữ liệu thì không có kết luận.
- **CLOSE_WITH_CAVEAT**: không có hit trong khi nguồn có dữ liệu; có thể đóng nhưng phải ghi rõ giới hạn.

4.6.2. Cây quyết định



Hình 5. Cây quyết định của luật khuyến nghị

Bảng 8. Luật xác định khuyến nghị và độ tin cậy

Điều kiện	Khuyến nghị	Tin cậy
Mọi bước khớp, judge $\text{TRUE_POSITIVE} \geq 0,7$	ESCALATE_TO_IR	HIGH nếu judge $\geq 0,8$ và PoC có bước kiểm tra kết quả; ngược lại MEDIUM
Mọi bước khớp, judge $\text{FALSE_POSITIVE} \geq 0,7$	TUNE_POC_OR_CLOSE	MEDIUM

Điều kiện	Khuyến nghị	Tin cậy
Mọi bước khớp, judge không rõ hoặc không có	INVESTIGATE_FURTHER	MEDIUM
Chỉ khớp một phần	INVESTIGATE_FURTHER	LOW (không judge) hoặc MEDIUM
Không khớp, một nguồn cần thiết có 0 bản ghi	COLLECT_DATA_THEN_RERUN	HIGH
Không khớp, nguồn có dữ liệu nhưng 0 bản ghi của host PoC; chạy lại không lọc host vẫn 0	CLOSE_WITH_CAVEAT	MEDIUM
Như trên nhưng chạy lại không lọc host có hit ở host khác	INVESTIGATE_FURTHER	LOW
Không khớp, nguồn có dữ liệu trong phạm vi tìm	CLOSE_WITH_CAVEAT	MEDIUM
Không khớp, không kiểm tra được độ phủ	CLOSE_WITH_CAVEAT	LOW

4.6.3. Lý giải các quyết định thiết kế

Chuỗi không đầy đủ không bao giờ lên escalate. Nếu chỉ một phần các bước khớp, giả thuyết về một chuỗi tấn công hoàn chỉnh chưa được ủng hộ, bất kể judge nói gì. Quy tắc này giữ cho một nhận định LLM đơn lẻ không thể đẩy hệ thống tới hành động tổn kém.

Trần độ tin cậy khi chưa chứng minh thành công. Một PoC không có bước nào trên trường kết quả (status, action, result, response, outcome) chỉ chứng minh được có hoạt động tương ứng, không chứng minh được hoạt động đó thành công. Trường hợp này độ tin cậy của ESCALATE_TO_IR bị hạ về MEDIUM và lý do được ghi vào báo cáo. Quy tắc xuất hiện từ lần chạy thử đầu tiên: phiên bản đầu của luật cho PoC khai thác Joomla độ tin cậy HIGH dù dữ liệu chỉ có yêu cầu web không có mã trạng thái.

Judge chỉ đẩy một bậc và chỉ khi tự tin. Judge dưới 0,7 không thay đổi kết quả. Advisor không thay đổi disposition hay confidence.

Thiếu nguồn là kết luận riêng. Khi một nguồn cần thiết có 0 bản ghi, kết quả được gọi bằng tên riêng chứ không gộp vào "rỗng"; đây là hiện thực trực tiếp của nguyên tắc ở mục 2.5.

Phạm vi rỗng khác với dữ liệu rỗng. Nguồn có dữ liệu trong cửa sổ nhưng không có bản ghi của host mà PoC nhắm tới là trường hợp thứ ba, không phải "thiếu nguồn" và cũng không phải "không có hoạt động". Hệ thống không tự chọn một cách đọc: nó chạy lại không lọc host và để kết quả quyết định. Nếu vẫn không có hit, khuyến nghị là đóng kèm cảnh báo (và nói rõ PoC chưa từng được thử trên host đó); nếu có hit ở host khác, khuyến nghị là điều tra với độ tin cậy thấp vì bằng chứng nằm ngoài phạm vi mà PoC khai báo.

4.6.4. Lựa chọn xếp hạng

Mỗi khuyến nghị đi kèm danh sách lựa chọn khả dĩ, xếp theo ưu tiên với lựa chọn của luật ở đầu. Với kết quả có bản ghi, các lựa chọn thuộc tập {escalate, điều tra thêm, tinh chỉnh/đóng}; với kết quả trống thuộc tập {bổ sung telemetry, đóng kèm cảnh báo}. Văn bản cho lựa chọn escalate nhắc người dùng xác nhận vai trò thật của máy được nêu (nạn nhân, nguồn tấn công hay cảm biến ghi log) trước khi cô lập, vì trong dữ liệu thực nghiệm máy xuất hiện nhiều nhất chính là một máy thu log.

4.7. Thiết kế bảo mật và quyền riêng tư

- **Bí mật:** khoá API chỉ nằm trong .env và biến môi trường của tiến trình. Tập model_config.json sinh ra chỉ chứa \${LLM_API_KEY} và \${PEAK_LLM_BASE_URL}. Đã kiểm tra rằng khoá không xuất hiện trong bất kỳ tệp kết quả nào.
- **Truy vấn:** mọi giá trị đưa vào SQL đều là tham số; tên cột và thao tác đi qua danh sách cho phép (allowlist); cửa sổ thời gian được kiểm tra định dạng; với Splunk có thêm cổng AST kiểm tra truy vấn gốc chỉ đọc.
- **Dữ liệu gửi cho LLM:** đây là rủi ro cần nêu rõ. Judge nhận tối đa mười hàng đã rút gọn, advisor nhận bản tóm tắt bằng chứng gồm tối đa năm hàng mẫu và các giá trị phổ biến, và PEAK nhận mô tả cấu trúc dữ liệu cùng kết quả đếm. Nếu endpoint LLM nằm ngoài tổ chức, các đoạn telemetry này rời khỏi môi trường. Đối với dữ liệu nhạy cảm cần dùng mô hình cục bộ hoặc chế độ --offline.
- **Thành phần ngoài:** PEAK Assistant tự công bố là chưa qua kiểm thử bảo mật; hệ thống chỉ nên chạy cục bộ và không mở cổng dịch vụ.

4.8. Cấu trúc đầu ra

Mỗi lần chạy tạo một thư mục theo thời gian (hoặc theo --out) chứa tệp summary.md/summary.json tổng hợp và một thư mục con cho mỗi PoC với các tệp sau.

Bảng 9. Các tệp đầu ra của một PoC

Tệp	Nội dung
recommendation.md	Báo cáo cho người quyết định, tiếng Việt
recommendation.json	Cùng nội dung ở dạng máy đọc, kèm phần thực thi, PEAK và siêu dữ liệu
peak_able.md	Bảng ABLE do PEAK sinh (hoặc từ PoC khi không dùng PEAK)
peak_hunt_plan.md	Kế hoạch săn do PEAK sinh
<poc_id>.json	Sổ cái thực thi: từng bước, số hàng, hàng khớp, nhật ký tinh chỉnh
act/	Bản nháp SPL và kết quả kiểm tra tĩnh, backlog, ghi chú stakeholder
ir/	Gói bàn giao cho IR khi có hit

Chương 5. Cài đặt hệ thống

5.1. Môi trường và công nghệ

Hệ thống được viết bằng Python 3.12, chạy trên Windows với môi trường ảo .venv; không có thành phần nào phụ thuộc hệ điều hành. Các thư viện chính:

Bảng 10. Công nghệ sử dụng

Thành phần	Vai trò	Ghi chú
Python 3.12	Ngôn ngữ	Yêu cầu của PEAK Assistant
PEAK Assistant	Prepare: ABLE, kế hoạch	Ghim theo commit dfabbb0, giấy phép MIT
AutoGen (autogen-agentchat, autogen-ext)	Khung đa tác tử mà PEAK dùng	Được kéo theo PEAK
SQLite	Kho telemetry CDB	Thư viện chuẩn sqlite3
Pydantic, PyYAML, requests	Hợp đồng dữ liệu, đọc cấu hình, gọi HTTP	Phụ thuộc lỗi
pytest, ruff	Kiểm thử, kiểm tra kiểu mã	Phụ thuộc phát triển
Splunk REST API	Adapter Splunk (tùy chọn)	Chưa chạy trên máy chủ thật trong đồ án

PEAK Assistant được khai báo là phụ thuộc **tùy chọn** (`pip install -e ".[peak]"`), nhờ đó cài đặt lỗi không phải kéo theo AutoGen, Streamlit và nhiều thư viện khác. Mọi import vào PEAK nằm trong thân hàm, nên mô-đun của hệ thống nạp được cả khi PEAK chưa cài.

5.2. Cấu trúc mã nguồn

Sau khi làm gọn, `src/hunting/` gồm các mô-đun sau với tổng khoảng 8.700 dòng.

Bảng 11. Cấu trúc mã nguồn

Đường dẫn	Dòng	Vai trò
<code>llm.py</code>	~215	Cấu hình LLM, gọi lại, bộ gọi đồng bộ
<code>prepare.py</code>	~220	Cầu nối PEAK Assistant
<code>recommend.py</code>	~500	Tóm tắt bằng chứng, luật khuyến nghị, advisor
<code>report.py</code>	~130	Dựng báo cáo Markdown và bảng tổng hợp
<code>pipeline.py</code>	~115	Điều phối một PoC từ đầu đến cuối
<code>cli.py</code>	~130	Dòng lệnh
<code>poc/</code>	~1.700	Mô hình PoC, nạp JSON, tác tử thực thi, judge, báo cáo

Đường dẫn	Dòng	Vai trò
adapters/	~3.300	Adapter CDB và Splunk, danh sách cho phép, kiểm soát
act/	~365	Bản nháp SPL, backlog, ghi chú stakeholder
contracts/, capabilities/, controller/, query_safety/	~1.550	Hợp đồng dữ liệu mà adapter cần, theo dõi chi phí
peak.py	~450	Công Prepare, phân tích thời lượng, cửa sổ, ABLE → quan sát cụ thể

Hai nguyên tắc tổ chức: các mô-đun mới (llm, prepare, recommend, report, pipeline, cli) chỉ phụ thuộc vào poc/ và adapters/ qua giao diện công khai; và không có mô-đun nào của lõi phụ thuộc trực tiếp vào PEAK ngoài prepare.py và llm.py.

5.3. Lớp LLM (`llm.py`)

5.3.1. Từ `.env` đến cấu hình PEAK

PEAK Assistant đọc cấu hình mô hình từ một tệp model_config.json có thể nội suy biến môi trường dạng \${TÊN}. Hệ thống đọc ba biến LLM_ENDPOINT, LLM_API_KEY, LLM_MODEL từ .env (hoặc từ biến môi trường, hoặc đối số --model), tách địa chỉ gốc ra khỏi đường dẫn /chat/completions, rồi sinh cấu hình chỉ chứa placeholder:

```
def model_config(self) -> dict:
    return {
        "version": "1",
        "providers": {"hunting-llm": {
            "type": "openai",
            "config": {"api_key": "${LLM_API_KEY}",
                      "base_url": "${PEAK_LLM_BASE_URL}",
                      "timeout": self.timeout, "max_tokens": self.max_tokens},
            "models": {self.model: {"model_info": {...}}},
        }},
        "defaults": {"provider": "hunting-llm", "model": self.model},
    }
```

Trường model_info là bắt buộc của AutoGen khi dùng tên mô hình không thuộc danh sách OpenAI. Hệ thống điền các giá trị trung tính (không hỗ trợ hình ảnh, không dùng gọi hàm) để mọi mô hình tương thích OpenAI đều dùng được. Khoá API và địa chỉ cơ sở được đặt vào os.environ của tiến trình ngay trước khi nạp cấu hình, nên không tệp nào trên đĩa chứa khoá.

5.3.2. Tính tùy chọn

Hàm LlmSettings.from_env ném LlmUnavailable khi thiếu cấu hình hoặc khi giá trị còn là placeholder của .env.example (chứa < hoặc bắt đầu bằng sk-or-...). configure_peak cũng ném LlmUnavailable nếu thư viện PEAK chưa cài. CLI bắt

ngoại lệ này, in một dòng thông tin (không phải lỗi) và tiếp tục chạy phần tắt định. Nhờ vậy cùng một lệnh chạy được trên máy có và không có LLM.

5.3.3. Gọi lại có backoff

Quan sát thực tế cho thấy endpoint LLM đôi lúc trả HTTP 404 model_not_found dù mô hình tồn tại; ứng dụng khách OpenAI không thử lại lỗi 404. Hàm sau gọi lại bất kỳ lời gọi bất đồng bộ nào với khoảng chờ tăng dần, và ném lại lỗi cuối nếu hết lượt:

```
RETRY_DELAYS = (3.0, 10.0, 25.0)

async def retry_async(factory, *, delays=RETRY_DELAYS, label="LLM call", notes=None):
    for attempt in range(len(delays) + 1):
        try:
            return await factory()
        except asyncio.CancelledError:
            raise
        except Exception as exc:
            if attempt >= len(delays):
                raise
            if notes is not None:
                notes.append(f"{label}: retry {attempt + 1}/{len(delays)} after {type(exc).__name__}")
            await asyncio.sleep(delays[attempt])
```

PeakLlm.__call__ (dùng cho judge và advisor) và hai bước ABLE, kế hoạch trong prepare.py đều dùng hàm này. Một sai cấu hình thật (khóa sai, tên mô hình sai) vẫn thất bại sau lượt cuối với nguyên thông báo gốc.

5.3.4. Vòng lặp sự kiện

PEAK là bất đồng bộ còn pipeline là đồng bộ. Hàm run_async tạo vòng lặp mới cho mỗi lần chạy, đóng vòng lặp đúng cách và cài một bộ xử lý ngoại lệ bỏ qua cảnh báo vô hại Event loop is closed do các ứng dụng khách HTTP bị dọn sau khi vòng lặp đã đóng. Cảnh báo này xuất hiện trong lần chạy thật đầu tiên và được loại bỏ ở đây; các lỗi khác vẫn được chuyển tiếp bình thường.

5.4. Cầu nối PEAK (prepare.py)

Hàm _peak_prepare thực hiện hai bước, mỗi bước bọc trong retry_async và trong asyncio.wait_for với thời hạn mặc định 420 giây:

```
async def _able() -> str:
    text = await asyncio.wait_for(
        able_table(hypothesis=hypothesis, research_document=research,
                    local_data_document=data_document, local_context=LOCAL_CONTEXT),
        timeout)
    if not text or text.startswith("Error while generating"):
        raise RuntimeError(text or "empty ABLE table") # able_table nuốt lỗi thành chuỗi
    return text
able = await retry_async(_able, label="ABLE", notes=result.notes)
```

Chi tiết quan trọng: hàm able_table của PEAK bắt mọi ngoại lệ và trả về chuỗi bắt đầu bằng Error while generating; nếu không nhận ra điều này, lỗi sẽ bị coi là

một bảng ABLE hợp lệ. Bước kế hoạch có kiểm tra tương tự với các chuỗi Could not create a hunt plan và no plan was generated.

PEAK và AutoGen in nhiều dòng traceback cho mỗi lời gọi lỗi. Ngữ cảnh `_quiet_peak` chuyển hướng đầu ra chuẩn và đầu ra lỗi, và nâng ngưỡng ghi log của các logger `autogen_*` lên mức nghiêm trọng trong lúc gọi PEAK; nguyên nhân lỗi vẫn được ghi lại bằng chữ trong `peak.notes`. Hàm `run_prepare` bọc tất cả: nếu 11m là rỗng thì dùng ABLE và kế hoạch dựng từ PoC; ngược lại thử tối đa hai lượt và, nếu cả hai thất bại, quay về chế độ này với ghi chú rõ ràng.

5.5. Bộ thực thi PoC (`poc/agent.py`)

`PocAgent.run` thực hiện: kiểm tra cổng Prepare, cắt cửa sổ theo `max_duration`, chạy vòng thực thi, gọi `judge` (nếu bật), ghi gói IR khi có hit, ghi sổ cái. Vòng thực thi `_execute_loop` có đặc tính đáng chú ý:

- Lượt 1 chạy mọi bước chính, mỗi bước gọi `adapter.execute_query(operation_id="search_text", search_terms=...)` với giới hạn quét `SCAN_LIMIT = 2000` hàng; sau khi áp dụng toán tử, tối đa `ROW_CAP = 100` hàng được giữ và `matched_total` ghi tổng số khớp.
- Các giá trị cụ thể rút từ ABLE của PoC (tên tệp, cờ dòng lệnh, địa chỉ IP, chuỗi trong ngoặc kép; không phải bảng ABLE do PEAK sinh) được AND thêm vào truy vấn; văn xuôi không thêm điều kiện nào. Host suy ra từ `able.location` cũng được dùng làm bộ lọc thực thể. Việc rút trích dùng biểu thức chính quy trong `peak.py`, và mọi điều kiện thêm này được ghi vào `StepResult.scope`.
- Nếu các hit ở bước đầu tiên đến từ đúng một máy khác với máy ABLE nêu, lượt 2 chạy lại các bước còn lại trên máy đó.
- Nếu lượt 1 hoàn toàn rỗng và PoC khai báo `fallbacks` thì chạy các bước thay thế; sau đó có thể chạy lại đúng các vị từ gốc một lần.
- Toán tử không bao giờ được nói: `EQUALS` không biến thành `CONTAINS` ở lượt thứ hai.

Hàm `_apply_op` hiện thực toán tử trên giá trị ô. `EQUALS` so khớp không phân biệt hoa thường với cả giá trị đầy đủ và phần tên tệp cuối đường dẫn; `MATCHES` dùng `re.search` và lùi về `CONTAINS` nếu biểu thức lỗi; `EXISTS` yêu cầu ô không rỗng và, nếu `value` rỗng, loại bỏ mọi hàng để tránh khớp bừa (một lỗi thật đã được phát hiện khi đánh giá trên dữ liệu lớn). Ở tầng truy xuất, `MATCHES` chỉ gửi cho adapter đoạn literal bắt buộc dài nhất của biểu thức (`_regex_literal`) và `EXISTS` được đẩy xuống SQL (`parameters={"require_nonempty": [trường]}`); nếu không, regex bị đưa nguyên vào `LIKE` sẽ không khớp gì.

5.6. Adapter

Adapter CDB mở một tệp SQLite và hiện thực `execute_query` với các thao tác có tham số. Với `search_text`, mỗi từ khoá tạo một điều kiện `COALESCE(cột, '') LIKE ?` trên các cột văn bản, nối bằng `OR` giữa cột và `AND` giữa các từ khoá; cửa sổ thời gian là hai điều kiện trên `timestamp`. Hai phương thức mới được thêm cho đồ án:

- `source_presence(window, source_kind)`: đếm số bản ghi trong cửa sổ có `native_type` thuộc tập tương ứng với loại nguồn; trả `None` nếu loại nguồn không biết.
- `describe_data()`: tạo tài liệu Markdown mô tả bảng, các cột, và với mỗi cặp (`native_type`, `event_id`) là số dòng, thời điểm đầu và cuối. Đây chính là "tài liệu dữ liệu cục bộ" mà PEAK nhận.

Adapter Splunk (`SplunkLiveAdapter`) giữ nguyên từ phiên bản trước: gọi REST API, kiểm tra cú pháp SPL qua điểm cuối parser mà không chạy tìm kiếm, và có cổng AST cho truy vấn gốc. Tám kiểm thử dành cho Splunk thật tự bỏ qua khi không có máy chủ tại cổng 8089.

5.7. Khuyến nghị và báo cáo

Mô-đun `recommend.py` gồm ba phần. `summarize_evidence` dựng `EvidenceSummary`: lấy hàng của các bước chính, khử trùng lặp, tính khoảng thời gian, đếm giá trị xoay trục, và gọi `source_presence` cho từng loại nguồn (có bộ nhớ đệm theo loại). `decide` hiện thực bảng luật ở mục 4.6, được trích ở đây phần nhánh có bản ghi khớp:

```
if ev.chain_complete:
    if judge_ok and judge.verdict == TRUE_POSITIVE:
        disposition, confidence = ESCALATE, "HIGH" if judge.confidence >= 0.8 else
"MEDIUM"
        if not outcome_observed and confidence == "HIGH":
            confidence = "MEDIUM" # chưa kiểm tra kết quả => chưa chứng minh thành
công
    elif judge_ok and judge.verdict == FALSE_POSITIVE:
        disposition, confidence = TUNE, "MEDIUM"
    else:
        disposition, confidence = INVESTIGATE, "MEDIUM"
else:
    disposition, confidence = INVESTIGATE, "LOW" if judge is None else "MEDIUM"
```

Hàm `advise` gửi cho LLM một lời nhắc chứa giả thuyết, kết luận do luật tính, các lý do, bản tóm tắt bằng chứng (cắt 6.000 ký tự), bảng ABLE (2.500 ký tự) và kế hoạch PEAK (6.000 ký tự), yêu cầu trả JSON chặt với ba mảng. Hàm chịu được đầu ra lệch chuẩn: thử tối đa ba lần khi JSON lỗi hoặc không có bước nào dùng được; chấp nhận mục bước là chuỗi thuần hoặc đối tượng có khoá `step/title/check` thay cho `action` và `reason/rationale` thay cho `why`; nếu thất bại vẫn trả khuyến nghị theo luật cùng một ghi chú giải thích. Hàm `advise` không có đường nào ghi vào `disposition` hay `confidence`.

Mô-đun `report.py` dựng báo cáo Markdown bằng tiếng Việt với các mục cố định: khuyến nghị và lý do, giới hạn, bảng lựa chọn, bằng chứng, judge, gợi ý bước tiếp theo, câu hỏi, rủi ro, kế hoạch PEAK, bản nháp SPL, chi phí và tái lập. Bản nháp SPL do act/ sinh từ các vị từ: EQUALS thành trường="giá trị", các toán tử còn lại thành match(trường, "(?i)giá trị"); một kiểm tra tĩnh từ chối các lệnh nguy hiểm như delete, outputlookup, sendemail.

5.8. Dòng lệnh

`cli.py` dùng `argparse` với các nhóm đối số: đầu vào PoC (`--poc`, `--poc-dir`, `--window`), nhà cung cấp telemetry (`--provider`, `--db`, các tham số Splunk), LLM (`--env`, `--model`, `--offline`, `--research`, `--peak-timeout`) và `--out`. Với mỗi PoC, lỗi nạp hoặc lỗi công Prepare được in ra và tính vào mã thoát, nhưng không dừng các PoC còn lại. Sau cùng ghi `summary.md` và `summary.json`.

5.9. Kiểm thử

Bộ kiểm thử gồm 101 bài, trong đó 93 chạy được và 8 bị bỏ qua vì cần Splunk thật. Kết quả cuối: 93 đạt, 8 bỏ qua, mã kiểm tra tĩnh ruff không báo lỗi. Các bài mới (`tests/unit/test_pipeline.py` và `tests/unit/test_scope_and_caps.py`) kiểm tra:

- **Luật khuyến nghị:** 11 tổ hợp tham số (bằng chứng $\times$ judge) ứng với bảng luật; chuỗi một phần không escalate dù judge tin cậy cao; trần độ tin cậy khi chưa có bước kiểm tra kết quả và mở trần khi có.
- **Rỗng không thành sạch:** thiếu nguồn cho `COLLECT_DATA_THEN_RERUN` với câu cảnh báo.
- **Advisor:** phân tích JSON có hàng rào mã; thử lại khi rác hoặc rỗng; chấp nhận dạng lệch chuẩn; lỗi LLM không đổi khuyến nghị.
- **Cấu hình LLM:** đọc `.env`, tách địa chỉ gốc, không để khoá lọt vào cấu hình, từ chối giá trị mẫu.
- **Chịu lỗi PEAK:** khi PEAK ném lỗi thì quay về PoC và có ghi chú; lỗi thoáng qua được thử lại thành công; cơ chế `retry_async` thành công sau vài lần và ném lại lỗi dai dẳng.
- **Độ phủ CDB:** đếm theo loại nguồn (và theo host), cơ cấu loại sự kiện, host ghi nguồn, mô tả dữ liệu.
- **Phạm vi ngằm và giới hạn hàng (mục 7.4):** phạm vi host rỗng phải được ghi nhận và chạy lại không lọc host (cả hai nhánh có hit và không hit); báo cáo ghi hiển thị / tổng khi chạm trần 100 hàng; MATCHES với regex thật tìm được; EXISTS không bị che bởi giới hạn quét; `_regex_literal` chỉ thu hẹp, không bỏ sót; cửa sổ SPL lấy từ PoC.
- **Đầu cuối:** chạy CLI trên một CSDL nhỏ ở chế độ `--offline`, và chạy CLI khi không có tệp `.env` nào.

Các bài này không gọi LLM thật; việc gọi thật được kiểm chứng bằng thực nghiệm ở Chương 7.

Chương 6. Hướng dẫn thực hành

Chương này hướng dẫn một người chưa biết hệ thống đi từ cài đặt đến chạy được cuộc săn đầu tiên, đọc kết quả, và tự viết PoC mới. Các lệnh ghi theo cú pháp Windows (PowerShell hoặc Git Bash) và đều đã được chạy thử trong quá trình thực hiện đồ án. Trên Linux hoặc macOS, thay `.venv\Scripts\python.exe` bằng `.venv/bin/python`.

6.1. Chuẩn bị môi trường

6.1.1. Yêu cầu

- Python 3.12 trở lên (PEAK Assistant không chạy trên bản thấp hơn).
- Git, để cài PEAK Assistant từ GitHub.
- Khoảng 2 GB dung lượng đĩa nếu nạp toàn bộ BOTS v1; chỉ vài MB nếu dùng mẫu nhỏ.
- Khoá API của một dịch vụ LLM tương thích OpenAI. **Đây là điều kiện tùy chọn**, xem mục 6.2.

6.1.2. Cài đặt lõi (không cần LLM)

```
git clone <địa-chỉ-kho> AI_Agent_Hunting
cd AI_Agent_Hunting
python -m venv .venv
.venv\Scripts\python.exe -m pip install -e ".[dev]"
```

Cài đặt này chỉ kéo theo pydantic, pyyaml, requests, cùng pytest và ruff. Kiểm tra:

```
.venv\Scripts\python.exe -m pytest tests -q
```

Kết quả mong đợi: 93 passed, 8 skipped. Tám bài bị bỏ qua cần máy chủ Splunk thật tại cổng 8089 và tự bỏ qua khi không có.

6.1.3. Cài thêm PEAK Assistant (tùy chọn)

```
.venv\Scripts\python.exe -m pip install -e ".[peak]"
```

Lệnh này cài PEAK Assistant từ GitHub tại commit đã ghim dfabbb0, kéo theo AutoGen và nhiều thư viện khác nên mất vài phút. Kiểm tra bằng `python -c "import peak_assistant";` không có lỗi nghĩa là đã cài xong.

6.2. Cấu hình LLM

6.2.1. Ba biến cần thiết

Sao chép `.env.example` thành `.env` rồi điền ba giá trị:

```
LLM_ENDPOINT=https://openrouter.ai/api/v1/chat/completions
```

```
LLM_API_KEY=<khoá-của-bạn>
LLM_MODEL=<tên-mô-hình>
```

LLM_ENDPOINT là địa chỉ đầy đủ tới /chat/completions của bất kỳ dịch vụ tương thích OpenAI nào (OpenRouter, OpenAI, một máy chủ cục bộ như Ollama hoặc vLLM). Có hai biến phụ: LLM_TIMEOUT (giây, mặc định 600) và LLM_MAX_TOKENS (mặc định 16000). Tập .env đã nằm trong .gitignore; **không bao giờ** đưa khoá vào mã nguồn, báo cáo hay ảnh chụp màn hình.

6.2.2. Ba mức dùng LLM

Bảng 12. Các chế độ chạy theo cấu hình LLM

Chế độ	Cách bật	Prepare	Judge và advisor	Khi nào dùng
Không LLM	--offline, hoặc .env chưa điền	ABLE và kế hoạch dựng từ PoC	Không có	Chưa có khoá; dữ liệu nhạy cảm; chạy nhanh, tái lập
LLM mặc định	.env đã điền	PEAK Assistant	Có	Chạy đầy đủ
Ghi đè mô hình	--model <tên>	PEAK Assistant	Có	Thử mô hình khác mà không sửa .env

Hệ thống nhận biết trường hợp .env còn giá trị mẫu (<your-key>, sk-or-...) và chuyển sang chế độ không LLM với một dòng thông tin, không báo lỗi. Điều này đã được kiểm thử bằng bài test_cli_runs_without_any_llm_configuration.

6.2.3. Chọn mô hình miễn phí

Khi chưa muốn trả phí, OpenRouter có các mô hình đánh dấu :free. Danh sách thay đổi liên tục, nên cách chắc chắn là hỏi trực tiếp danh mục của dịch vụ rồi lọc theo giá bằng không:

```
curl https://openrouter.ai/api/v1/models
```

Trong kết quả, mô hình có pricing.prompt và pricing.completion cùng bằng "0" là miễn phí. Không phải mô hình nào cũng gọi được: một số bị giới hạn tốc độ, một số không trả JSON, một số không phải mô hình văn bản. Mục 7.5 trình bày kết quả thử thật và mô hình đã chạy trọn bốn PoC. Để dùng:

```
.venv\Scripts\python.exe main.py --poc-dir pocs --model "nvidia/nemotron-3-super-120b-a12b:free"
```

Lưu ý: mô hình miễn phí thường có giới hạn số lượt gọi mỗi phút/ngày và có thể dùng dữ liệu gửi lên để huấn luyện; đừng gửi telemetry nhạy cảm tới chúng.

6.3. Chuẩn bị dữ liệu telemetry

6.3.1. Mẫu nhỏ để thử nhanh

```
.venv\Scripts\python.exe scripts/seed_botstv1_sample.py --db data/cdb_sample.sqlite
```

Lệnh tạo một CSDL SQLite với khoảng vài chục sự kiện đại diện cho các pha tấn công của BOTS v1. Đủ để kiểm tra luồng chạy, nhưng chưa đủ để thấy các hiện tượng thật như kết quả rỗng do thiếu nguồn.

6.3.2. Bộ dữ liệu đầy đủ

Kết quả ở Chương 7 dùng data/botsv1_eval.sqlite với 4.417.543 dòng. Tập này lớn và nằm ngoài git. Để dựng lại cần tải các tập CSV nén của BOTS v1 [15] vào data/raw/, rồi chạy:

```
.venv\Scripts\python.exe scripts/ingest_botsv1_eval.py # Security log + sysmon + DNS
.venv\Scripts\python.exe scripts/ingest_http.py # stream:http cho PoC Joomla
```

Các tập lệnh đọc theo luồng, không giữ toàn bộ CSV trong bộ nhớ, và chỉ giữ các loại sự kiện phục vụ đánh giá (đăng nhập 4624/4625, tạo tiến trình 4688, SMB 5140/5145, sysmon, DNS, HTTP). Lược đồ CSDL là một bảng events gồm các cột timestamp, event_id, native_type, host, user, pid, ppid, cmdline, image, ip, port, domain, file_path, action, status, raw_ref.

6.3.3. Kiểm tra dữ liệu có gì

Trước khi viết PoC, hãy xem CSDL thật sự chứa gì. Đây là bài học lớn nhất của đồ án (mục 7.4): nhiều PoC rỗng chỉ vì dữ liệu không có loại sự kiện đó.

```
.venv\Scripts\python.exe -c "from hunting.adapters import CdbAdapter;
print(CdbAdapter('data/botsv1_eval.sqlite').describe_data())"
```

Kết quả là bảng Markdown liệt kê từng cặp native_type/event_id với số dòng và khoảng thời gian; đây cũng chính là tài liệu mà PEAK nhận làm "dữ liệu cục bộ".

6.4. Chạy cuộc săn đầu tiên

6.4.1. Một PoC, không LLM

```
.venv\Scripts\python.exe main.py --poc pocs/poc-joomla-rce.json --offline --out
artifacts/runs/thu1
```

Màn hình in một khối cho mỗi PoC:

```
=== poc-joomla-rce window=2016-08-10T21:36:00Z/2016-08-10T22:00:00Z
verdict=MATCHED obs=200 -> INVESTIGATE_FURTHER (MEDIUM) | PEAK=no
```

Khi không dùng LLM, Joomla dừng ở INVESTIGATE_FURTHER vì không có judge nào đánh giá ngữ cảnh; với LLM, cùng PoC cho ESCALATE_TO_IR (MEDIUM). Hệ thống ghi rõ điều đó trong mục giới hạn của báo cáo.

6.4.2. Toàn bộ PoC, có LLM

```
.venv\Scripts\python.exe main.py --poc-dir pocs --out artifacts/runs/day-du
```

Mỗi PoC mất vài giây đến vài phút tùy mô hình; phần lớn thời gian là hai lượt gọi PEAK (ABLE và kế hoạch). Nếu thấy dòng PEAK=no, mở recommendation.json và đọc peak.notes để biết lý do quay về chế độ không LLM.

6.4.3. Các tùy chọn thường dùng

Bảng 13. Tham chiếu nhanh tùy chọn dòng lệnh

Tùy chọn	Tác dụng
--poc FILE (lập được), --poc-dir DIR	Chọn PoC
--window START/END	Ghi đè cửa sổ thời gian của mọi PoC
--db PATH	Đường dẫn CSDL SQLite
--provider splunk kèm --splunk-url, --splunk-user, --splunk-index	Dùng Splunk thay cho SQLite
--env FILE, --model TÊN	Tập cấu hình LLM; ghi đè mô hình
--offline	Bỏ hoàn toàn PEAK và mọi lời gọi LLM
--research	Bật tác tử nghiên cứu của PEAK (cần máy chủ MCP)
--peak-timeout GIÂY	Hạn cho mỗi bước PEAK (mặc định 420)
--out DIR	Thư mục kết quả

6.5. Đọc và dùng báo cáo

Mở recommendation.md của một PoC. Nên đọc theo thứ tự sau, vì thứ tự đó phản ánh mức độ quan trọng đối với người quyết định.

1. **Dòng đầu: khuyến nghị và độ tin cậy.** Ví dụ ESCALATE_TO_IR (MEDIUM). Đây là gợi ý, không phải quyết định.
2. **Lý do.** Mỗi lý do gắn với một sự kiện kiểm chứng được: số bước khớp, khoảng thời gian hit, nhận định judge.
3. **Giới hạn của kết luận.** Mục dễ bị bỏ qua nhất nhưng quan trọng nhất. Với kết quả rộng, mục này nói rõ cửa sổ đã quét, rằng predicate là literal, liệt kê các loại sự kiện thực có trong nguồn (để bạn tự kiểm tra loại sự kiện cần tìm có trong đó không), và nêu các điều kiện phụ suy ra từ ABLE (host, chuỗi AND). Nếu có bước bị cắt ở 100 hàng, mục này ghi tổng số khớp.
4. **Bảng lựa chọn.** Các hành động khả dĩ xếp theo ưu tiên.
5. **Bảng chứng.** Bảng từng bước với số bản ghi nguồn trong cửa sổ, trong phạm vi lọc và số khớp (hiển thị / tổng, dấu $\geq$ nghĩa là quét chạm giới hạn nên tổng chỉ là cận dưới); mục "Phạm vi truy vấn thực tế"; các giá trị xoay trục (máy, IP, miền); vài hàng mẫu. Đây là chỗ để tự kiểm chứng.
6. **Phần do LLM viết** (judge, bước tiếp theo, câu hỏi, rủi ro, kế hoạch PEAK): luôn được gắn nhãn "chỉ mang tính tham khảo".

Ba tình huống thường gặp và cách xử lý:

Bảng 14. Từ khuyến nghị đến hành động của người sẵn

Khi báo cáo nói	Người sẵn nên
ESCALATE_TO_IR	Mở bằng chứng, kiểm tra vai trò thật của máy ở

Khi báo cáo nói	Người sẵn nên
	"Top host" (nạn nhân hay cảm biến), tìm bước kiểm tra kết quả (status), rồi mới chuyển gói trong ir/ cho IR
COLLECT_DATA_THEN_RERUN	Làm việc với đội hạ tầng để bật thu thập nguồn bị thiếu; không đóng cuộc săn
CLOSE_WITH_CAVEAT	Đọc từng giới hạn; nếu chấp nhận được thì đóng và lưu lại các giới hạn như ghi chú tri thức
INVESTIGATE_FURTHER	Xem bước nào không khớp và vì sao; bổ sung bước hoặc mở rộng cửa sổ
TUNE_POC_OR_CLOSE	Thêm điều kiện loại trừ cho hoạt động hợp lệ, hoặc đóng PoC

6.6. Viết PoC mới

6.6.1. Cấu trúc

Một PoC là tệp JSON. Hãy xem ví dụ đầy đủ tại Phụ lục A. Các trường bắt buộc của công Prepare: topic, able (đủ behavior, location, evidence; actor được để trống), research_refs, scope, max_duration, plan. Các trường thực thi: steps (bắt buộc), fallbacks, references, expected_chain, time_window.

6.6.2. Quy trình năm bước

1. **Phát biểu giả thuyết cụ thể và kiểm chứng được.** Tốt: "một địa chỉ IP gửi nhiều yêu cầu có chuỗi acunetix tới site Joomla". Kém: "có ai đó tấn công website".
2. **Xem dữ liệu có gì** (mục 6.3.3). Nếu không có nguồn nào chứa dấu hiệu bạn tìm, hãy dừng và coi đó là phát hiện về khoảng trống dữ liệu.
3. **Cẩn thận với `able.location`.** Nếu trường này chứa một token giống tên máy (ví dụ we1149srv), **mọi bước sẽ chỉ tìm trên máy đó** (báo cáo ghi rõ trong mục phạm vi truy vấn). Chỉ ghi tên máy khi bạn thật sự muốn giới hạn, và kiểm tra bằng describe_data/bảng độ phủ rằng máy đó thực sự ghi nguồn bạn cần: nhật ký web trong BOTS v1 nằm dưới tên máy thu log splunk-02, không phải máy client. Tương tự, các chuỗi cụ thể (tên tệp, cờ -enc, IP, chuỗi trong ngoặc kép) trong able.behavior/able.evidence được AND vào mọi bước.
4. **Chọn trường và toán tử.** Dùng EQUALS cho giá trị chính xác (tên tệp, tên miền); CONTAINS cho chuỗi con; MATCHES khi cần biểu thức chính quy; EXISTS khi chỉ cần trường có giá trị.
5. **Thêm một bước kiểm tra kết quả nếu dữ liệu có.** Bước trên trường status, action, result hoặc response cho phép hệ thống nâng độ tin cậy khi leo thang; thiếu bước này, giới hạn "chưa chứng minh thành công" sẽ luôn xuất hiện.
6. **Đặt `time\_window` hợp lý** và chạy thử với --offline trước, rồi mới bật LLM.

6.6.3. Chạy thử ví dụ

Kho có sẵn pocs/examples/poc-web-scanner-acunetix.json. Chạy:

```
.venv\Scripts\python.exe main.py --poc pocs/examples/poc-web-scanner-acunetix.json --offline
```

Kết quả khi chạy thật trên BOTS v1: 204 bản ghi hiển thị, 3 trên 3 bước có kết quả (100 / ≥ 1.999 , 6 và 100 / ≥ 2.000), tất cả từ địa chỉ 40.80.148.42, hit đầu tiên lúc 21:36:45; khuyến nghị INVESTIGATE_FURTHER (MEDIUM) vì ở chế độ --offline không có judge. Bước tìm acunetix chỉ có 6 hàng, đủ để nhận diện máy quét.

6.6.4. Những lỗi người mới hay mắc

Bảng 15. Lỗi thường gặp khi viết PoC

Triệu chứng	Nguyên nhân thường gặp	Cách sửa
PoC bị từ chối trước khi chạy	Thiếu trường của cổng Prepare	Đọc thông báo; điền trường thiếu
Kết quả luôn rỗng	Sai trường hoặc sai dạng giá trị (hoa thường không thành vấn đề); hoặc bị lọc theo host ngầm	Xem mục "Phạm vi truy vấn thực tế" và cột "Trong phạm vi lọc" của báo cáo; chạy describe_data, nhìn mẫu hàng thật trong CSDL
EQUALS không khớp đường dẫn đầy đủ	Giá trị ghi cả đường dẫn nhưng tên tệp trong dữ liệu khác	Dùng chỉ tên tệp (powershell.exe)
Quá nhiều hit vô nghĩa	Dùng CONTAINS với chuỗi quá ngắn	Dùng EQUALS hoặc MATCHES chính xác hơn, thêm bước loại trừ
COLLECT_DATA_THEN_RERUN	Nguồn đúng là không có dữ liệu trong cửa sổ	Kiểm tra source_kind và time_window trước khi kết luận

6.7. Dùng với Splunk thật

Adapter Splunk dùng REST API. Cần đặt mật khẩu qua biến môi trường (không qua dòng lệnh):

```
set SPLUNK_PASSWORD=...  
.venv\Scripts\python.exe main.py --poc-dir pocs --provider splunk --splunk-url  
https://localhost:8089 --splunk-user admin --splunk-index botsv1
```

Cần lưu ý trung thực: trong khuôn khổ đồ án, adapter này chỉ được kiểm thử bằng các bài tự bỏ qua khi không có máy chủ; chưa có lần chạy đầy đủ nào trên Splunk thật. Adapter Splunk cũng chưa có phương thức source_presence, nên với Splunk độ phủ nguồn được ghi là "không kiểm tra được" và kết quả rỗng sẽ có độ tin cậy LOW. Người dùng nên chạy thử trên một chỉ mục nhỏ và tự đối chiếu số bản ghi trước khi tin kết quả.

6.8. Xử lý sự cố

Bảng 16. Sự cố thường gặp và cách xử lý

Hiện tượng	Giải thích	Xử lý
------------	------------	-------

Hiện tượng	Giải thích	Xử lý
[i] LLM is optional and not available (...) rồi chạy tiếp	.env thiếu hoặc còn giá trị mẫu	Bình thường; điền khoá nếu muốn dùng LLM
PEAK Assistant is not installed	Chưa cài extra peak	<code>pip install -e "[peak]"</code>
PEAK=no kèm ghi chú HTTP 404 model_not_found	Endpoint trả lỗi thoát qua	Đã tự gọi lại ba lần; nếu vẫn lỗi, thử --model khác
HTTP 401	Khoá sai hoặc hết hạn	Kiểm tra LLM_API_KEY (không in khoá ra màn hình)
HTTP 429	Vượt giới hạn tốc độ, hay gặp với mô hình miễn phí	Đợi hoặc đổi mô hình; hệ thống đã gọi lại có chờ
Hết thời gian ở bước PEAK	Mô hình chậm	Tăng --peak-timeout hoặc LLM_TIMEOUT
Advisor ghi "không dùng được"	Mô hình trả JSON sai ba lần	Khuyến nghị theo luật vẫn đúng; thử mô hình khác
Không tìm thấy botsv1_eval.sqlite	Tệp ngoài git	Dùng theo mục 6.3.2 hoặc dùng --db data/cdb_sample.sqlite

6.9. Quy trình tái lập kết quả của luận văn

Để chạy lại thực nghiệm của Chương 7: dựng CSDL (6.3.2), điền .env, rồi chạy `main.py --poc-dir pocs --out artifacts/runs/tai-lap`. Phần tắt định (số bản ghi khớp, độ phủ) phải giống hết; phần LLM (văn bản ABLE, kế hoạch, nhận định judge, số token) sẽ khác từng lần, chỉ kết luận (disposition, độ tin cậy) được kỳ vọng ổn định. Thư mục `results/botsv1-peak-run/` lưu bản chạy đã dùng trong luận văn.

Chương 7. Thực nghiệm và đánh giá

Chương này trình bày các lần chạy thật của hệ thống. Mọi con số lấy từ tệp kết quả trong `results/botsv1-peak-run/` và `artifacts/runs/`, hoặc từ lệnh kiểm tra chạy lại khi viết chương này. Phần nào chưa kiểm chứng được sẽ được nêu rõ ở mục 7.9.

7.1. Thiết lập thực nghiệm

Dữ liệu. CSDL `data/botsv1_eval.sqlite` có 4.417.543 sự kiện trải trên 28 ngày (từ 2016-08-01 đến 2016-08-28), khoảng 154 nghìn dòng mỗi ngày, trừ hai ngày cao hơn là 10/8 (179 nghìn, ngày tấn công Joomla) và 24/8 (224 nghìn, ngày có dữ liệu DNS).

Bảng 17. Thành phần của CSDL đánh giá

Loại sự kiện (native_type/event_id)	Số dòng
process_creation / 4688	3.642.895
authentication / 4624 (đăng nhập thành công)	579.580
smb / 5140	63.859
web_request (stream:http)	39.010
smb / 5145	55.023
dns (stream:dns, chỉ ngày 24/8)	35.904
smb / 4648	1.206
process_creation / 1 (sysmon)	66

Điểm cần chú ý ngay: không có sự kiện đăng nhập thất bại (4625), không có tệp, và DNS chỉ có trong một ngày. Điều này quyết định kết quả của ba trong bốn PoC.

Bốn PoC. Đây là các PoC có sẵn trong kho, không được viết lại để "chạy được".

Bảng 18. Bốn PoC thực nghiệm

PoC	Giả thuyết	Kỹ thuật ATT&CK	Vị từ chính	Cửa sổ
poc-joomla-rce	Quét và khai thác Joomla trên site nạn nhân	T1190	domain EQUALS imreallynotbatman.com và cmdline CONTAINS /joomla/ (web)	10/8, 21:36–22:00
poc-bruteforce-we1149srv	Dò mật khẩu tài khoản quản trị	T1110	cmdline CONTAINS Logon Failed và user EQUALS admin (authentication)	21/8, cả ngày
poc-c2-beacon-networkfilter	Beacon tới tên miền C2	T1071.001	cmdline CONTAINS ad.networkfilter.co và /banner/ (web)	21/8, cả ngày
poc-pdf-exploit-enc	PowerShell mã hoá, ẩn cửa sổ sau khi mở PDF độc	T1059.001	image EQUALS powershell.exe, cmdline CONTAINS -enc, -w hidden	21/8, cả ngày

PoC	Giả thuyết	Kỹ thuật ATT&CK	Vị từ chính	Cửa sổ
			(process)	

Mô hình LLM và lần chạy. Ba cấu hình được so sánh: (i) --offline, không LLM; (ii) LLM_MODEL=auto của OpenRouter (dịch vụ tự chọn mô hình mỗi yêu cầu; một lần nhận thấy được chọn là deepseek/deepseek-v4.1-flash); (iii) nvidia/nemotron-3-super-120b-a12b:free, mô hình miễn phí. Cùng PEAK Assistant tại commit dfabbb0, cùng dữ liệu, cùng PoC. Thực nghiệm chạy trên một máy Windows 11, Python 3.12.

7.2. Kết quả chính

Các kết quả dưới đây là của bản hệ thống đã sửa ba lỗi phát hiện ở lượt rà soát cuối (mục 7.4, lỗi 8–10). Bản chạy trước đó cho các kết luận trùng ở bốn PoC nhưng ba PoC rỗng đúng **vì lý do sai**; điểm này được phân tích ở mục 7.2.2.

Bảng 19. Kết quả bốn PoC với mô hình auto

PoC	Bản ghi hiển thị	Số khớp tổng	Bước khớp	Khuyến nghị	Tin cậy	Judge
poc-joomla-rce	200	≥ 1.999 và ≥ 2.000 (quét chạm giới hạn)	2/2	ESCALATE_TO_IR	MEDIUM	TRUE_POSITIVE, 0,85
poc-bruteforce-we1149srv	0	0	0/2	CLOSE_WITH_CAVEAT	MEDIUM	không chạy (không có hit)
poc-c2-beacon-networkfilter	0	0	0/2	CLOSE_WITH_CAVEAT	MEDIUM	không chạy
poc-pdf-exploit-enc	0	0	0/3	CLOSE_WITH_CAVEAT	MEDIUM	không chạy

Ghi chú: trong tệp JSON, trường judge của ba PoC rỗng được ghi NO_SIGNAL với độ tin cậy 0, là giá trị mặc định khi không có hàng để đánh giá, không phải nhận định thật của LLM.

Phần tắt định ổn định: cả ba cấu hình (không LLM, auto, Nemotron miễn phí) cho cùng số bản ghi hiển thị (200 và ba lần 0) và cùng cơ cấu độ phủ.

7.2.1. PoC Joomla: có hit, kết luận ở mức vừa phải

Hệ thống giữ 200 bản ghi làm bằng chứng (100 cho mỗi bước), tắt cả từ một địa chỉ 40.80.148.42 tới imreallynotbatman.com, trong khoảng 21:36:45 đến 21:40:57. Số khớp thật lớn hơn nhiều: mỗi bước có ít nhất khoảng 2.000 hàng khớp trong cửa sổ 24 phút (lượt quét dừng ở giới hạn 2.000 hàng nên đó chỉ là cận dưới). Phiên bản trước

báo "199 bản ghi", một con số do giới hạn 100 hàng và một hàng bị bộ lọc loại, và không cho người đọc biết điều đó; báo cáo hiện ghi 100 / ≥1999 và 100 / ≥2000. Các hàng mẫu chứa /acunetix-wvs-test-for-some-inexistent-file, đường dẫn ngẫu nhiên tám ký tự và các thành phần /joomla/index.php/component/search/: đặc trưng của máy quét Acunetix duyệt thành phần Joomla.

Khuyến nghị là ESCALATE_TO_IR nhưng **MEDIUM, không phải HIGH**, và lý do được ghi thẳng trong báo cáo: dữ liệu web chỉ có miền và đường dẫn, không có mã trạng thái, và PoC không có bước nào kiểm tra kết quả, nên chỉ chứng minh được hoạt động quét, chưa chứng minh khai thác thành công. Mục "Rủi ro nếu quyết định sai" do advisor viết nêu đúng điểm này và còn gợi ý rằng mẫu Acunetix có thể là một đợt quét hợp pháp. Đây là hành vi mong muốn: kết luận thận trọng hơn cái mà một nhãn "MATCHED" đơn thuần gợi ra. Báo cáo cũng nhắc người dùng kiểm tra vai trò thật của máy splunk-02, vốn là máy ghi log chứ không phải nạn nhân.

Lưu ý lịch sử: phiên bản đầu của bộ luật cho kết quả HIGH với cùng bằng chứng. Việc đọc báo cáo đầu tiên mới làm lộ ra rằng độ tin cậy này không có căn cứ; luật trần outcome_observed được thêm vào sau đó (mục 4.6.3).

7.2.2. Ba PoC rỗng: không phải "sạch", và không hề được tìm đúng chỗ

Đây là phát hiện quan trọng nhất của lượt rà soát cuối. Cả ba PoC rỗng có able.location chứa tên máy we1149srv ("we1149srv authentication log", "egress web traffic from we1149srv", "we1149srv and workstations opening email attachments"). Hàm suy ra phạm vi ABLE biến tên máy đó thành bộ lọc host = we1149srv cho **mọi bước**, và điều này không hiện ra trong predicate, báo cáo hay tài liệu. Khi đếm độ phủ trong đúng phạm vi đó, cả ba đều bằng không.

Bảng 20. Phạm vi truy vấn và độ phủ của ba PoC rỗng (cửa sổ 21/8)

PoC	Nguồn	Bản ghi nguồn trong cửa sổ	Trong phạm vi host = we1149srv	Host thực sự ghi nguồn	Chạy lại không lọc host
poc-bruteforce-we1149srv	authentication	20.657	0	we9748srv (218), we5364srv (107), we1864srv (75)	0 bản ghi
poc-c2-beacon-networkfilter	web	566	0	splunk-02 (566)	0 bản ghi
poc-pdf-exploit-enc	process	129.775	0	we9748srv (1.335), we5364srv (630), we1864srv (537)	0 bản ghi

Với PoC c2-beacon, vấn đề mang tính cấu trúc: toàn bộ 39.010 dòng web trong CSDL có host = splunk-02 (máy thu log), nên bộ lọc theo máy client không thể khớp bất kỳ dòng web nào, kể cả khi beacon có thật. Phiên bản trước báo "nguồn web có 566 bản ghi trong cửa sổ" (đúng nhưng đếm mọi host) trong khi phạm vi tìm kiếm thực tế là 0 dòng; kết luận CLOSE_WITH_CAVEAT tình cờ đúng chỉ vì dữ liệu cũng không chứa networkfilter ở bất cứ đâu.

Bản đã sửa xử lý phạm vi rộng thành một trường hợp riêng. Hệ thống đếm độ phủ cả toàn cửa sổ lẫn trong phạm vi host, liệt kê host thực sự ghi nguồn, rồi chạy lại cùng PoC một lần **không lọc host** (thư mục unscoped_probe/). Cả ba lần chạy lại đều cho 0 bản ghi, nên khuyến nghị là CLOSE_WITH_CAVEAT (MEDIUM) với lý do ghi đủ hai vế: dữ liệu không chứa dấu hiệu ở bất kỳ host nào, và host nêu trong PoC không ghi nguồn này nên PoC chưa từng được thử trên host đó. Kết luận cuối vẫn là CLOSE_WITH_CAVEAT như trước, nhưng giờ có lý do đúng và có đo.

Độc lập với phạm vi host, truy vấn trực tiếp trên toàn CSDL (mọi host, mọi ngày) cho 0 dòng với từng chuỗi tín hiệu cần tìm:

Bảng 21. Dấu hiệu cần tìm có trong dữ liệu không (toàn CSDL 4.417.543 dòng)

PoC	Dấu hiệu	Số dòng khớp	Loại sự kiện thực có trong nguồn (cửa sổ 21/8)
poc-bruteforce-we1149srv	Logon Failed; user = admin	0; 0	chỉ authentication/4624 (đăng nhập thành công), không có 4625
poc-c2-beacon-networkfilter	networkfilter	0	web_request (chỉ có miền và đường dẫn)
poc-pdf-exploit-enc	powershell.exe cùng - enc; -w hidden	0; 0	process_creation/4688 (các dòng splunk-powershell.exe là công cụ của Splunk)

Cột cuối của bảng hiện nay cũng được hệ thống tự liệt kê trong báo cáo (mục "giới hạn của kết luận"), nên người săn không phải tự truy vấn để biết rằng nguồn xác thực chỉ có đăng nhập thành công. Hệ thống vẫn **chưa tự đối chiếu** loại sự kiện này với predicate; nó chỉ trưng bày để người săn đối chiếu (mục 8.3).

Mỗi PoC chỉ quét một ngày trong 28 ngày (3,6% khoảng dữ liệu), nên kể cả loại sự kiện có trong dữ liệu, các ngày khác vẫn chưa được xem. Người đọc nên coi kết quả CLOSE_WITH_CAVEAT ở đây là "không tìm thấy trong phạm vi đã quét", đúng như nhãn.

7.3. So sánh ba cấu hình

Bảng 22. Cùng bốn PoC dưới ba cấu hình

PoC	--offline	auto	Nemotron miễn phí
-----	-----------	------	-------------------

PoC	--offline	auto	Nemotron miễn phí
poc-joomla-rce	INVESTIGATE_FURTHER (MEDIUM)	ESCALATE_TO_IR (MEDIUM)	ESCALATE_TO_IR (MEDIUM)
poc-bruteforce-we1149srv	CLOSE_WITH_CAVEAT	CLOSE_WITH_CAVEAT	CLOSE_WITH_CAVEAT
poc-c2-beacon-networkfilter	CLOSE_WITH_CAVEAT	CLOSE_WITH_CAVEAT	CLOSE_WITH_CAVEAT
poc-pdf-exploit-enc	CLOSE_WITH_CAVEAT	CLOSE_WITH_CAVEAT	CLOSE_WITH_CAVEAT

Ba nhận xét. Thứ nhất, phần quyết định giữa ba cấu hình khác nhau ở đúng một chỗ: judge đóng góp vào Joomla. Không có LLM, hệ thống nói trung thực rằng "chuỗi khớp đủ nhưng chưa ai đánh giá ngữ cảnh" và dừng ở INVESTIGATE_FURTHER. Thứ hai, hai mô hình LLM rất khác nhau về nguồn gốc cho cùng kết luận, và độ tin cậy judge dao động (0,85 và 0,92 trong lần chạy này; các lần chạy trước từng ra 0,88, 0,92, 0,97), điều này đúng với dự đoán rằng judge không ổn định và nên chỉ dùng làm tham khảo. Thứ ba, ba PoC rỗng không đổi, vì judge không chạy khi không có hàng nào, và luật rỗng không phụ thuộc LLM.

Về chi phí gọi LLM do judge và advisor (số lời gọi và token do bộ đo của hệ thống ghi lại, không tính phần bên trong PEAK vì PEAK không báo token):

Bảng 23. Số lời gọi và token của judge/advisor

PoC	auto: lời gọi / token	Nemotron: lời gọi / token
poc-joomla-rce	2 / 9.524	2 / 7.280
poc-bruteforce-we1149srv	1 / 7.004	1 / 4.814
poc-c2-beacon-networkfilter	1 / 6.695	1 / 6.362
poc-pdf-exploit-enc	1 / 8.087	1 / 4.949

Token tăng so với bản trước vì advisor nhận thêm phạm vi truy vấn, cơ cấu loại sự kiện và kết quả chạy lại. Phần chiếm nhiều thời gian nhất và không được đo token là hai lượt gọi PEAK (ABLE và kế hoạch), mỗi lượt là một cuộc hội thoại đa tác tử nhiều lượt. Đây là hạn chế đo lường ghi ở mục 8.3.

7.4. Các lỗi đã phát hiện nhờ thực nghiệm

Giá trị lớn của việc chạy thật nằm ở những thứ kiểm thử đơn vị không bắt được. Bảng sau liệt kê chúng theo thứ tự thời gian.

Bảng 24. Lỗi phát hiện khi chạy thật và cách xử lý

#	Hiện tượng	Nguyên nhân	Xử lý
1	image EQUALS powershell.exe cho 100 hit trên dữ liệu sạch	Tầng tìm LIKE khớp cả splunk-powershell.exe	Bộ lọc chính xác ở tầng hai, mọi toán tử (từ đánh giá trước đó; có bài hồi quy)
2	Bước EXISTS với giá trị rỗng khớp hàng đầu tiên	Không có điều kiện giá trị	EXISTS rỗng trả 0 hàng

#	Hiện tượng	Nguyên nhân	Xử lý
3	Báo Event loop is closed sau mỗi lần chạy	Ứng dụng khách HTTP đóng sau vòng lặp	run_async và bộ xử lý ngoại lệ im lặng
4	Lỗi 404 model_not_found thoáng qua	Endpoint chuyển yêu cầu tới nhà cung cấp, đôi lần trả 404	Gọi lại có backoff; đo lại 1/15 (mục 7.5)
5	Độ tin cậy HIGH cho kết quả chưa chứng minh được thành công	Luật chưa tách quét và khai thác	Trần outcome_observed
6	Advisor trả JSON sai hoặc danh sách rỗng ở 2/4 PoC với auto	Mô hình không tuân thủ định dạng	Thử tới 3 lần, chấp nhận nhiều dạng, ghi lý do khi thất bại
7	able_table của PEAK nuốt lỗi thành chuỗi Error while generating...	Cách PEAK xử lý ngoại lệ	Nhận ra chuỗi lỗi và coi là lỗi thật để thử lại
8	Ba PoC rỗng bị lọc ngầm theo host = we1149srv, host không ghi nguồn tương ứng; độ phủ báo 20.657/566/129.775 bản ghi trong khi phạm vi thực tế là 0	Host suy ra từ able.location không hiển thị trong predicate hay báo cáo	Hiển thị phạm vi; đếm độ phủ trong phạm vi; chạy lại không lọc host; luật riêng (mục 7.2.2)
9	MATCHES với regex thật (acunet.x) cho 0 hàng dù acunetix cho 6; EXISTS dùng tên trường làm từ khoá	Tầng truy xuất đưa nguyên regex vào LIKE	Thu hẹp bằng đoạn literal bắt buộc; EXISTS đẩy xuống SQL
10	Joomla báo 199 bản ghi (bước 1 chỉ 99) mà không nói đã chạm giới hạn; SPL dùng earliest=-14d cố định	Chỉ lấy 100 hàng rồi mới lọc; cửa sổ SPL không lấy từ PoC	Quét 2.000 hàng rồi lọc, báo hiển thị / tổng; SPL dùng cửa sổ của PoC

Lỗi số 6 đáng nói thêm. Trước khi sửa, hai trong bốn PoC không có phần bước tiếp theo, và không có cảnh báo nào cho biết LLM đã trả sai: báo cáo trông "hoàn chỉnh" nhưng thiếu một phần. Sau khi sửa, cả bốn PoC có đủ 5 bước, 5 câu hỏi và 5 rủi ro với auto; với Nemotron là 5/5/5, 5/3/5, 5/5/5 và 5/5/5 (bruteforce, c2, Joomla, pdf-exploit). Lần chạy cuối không có traceback nào trong nhật ký.

Ba lỗi 8–10 được tìm thấy ở lượt rà soát cuối bằng cách đối chiếu mô tả trong luận văn với mã nguồn rồi truy vấn thẳng vào dữ liệu, không phải qua kiểm thử đơn vị. Lỗi 8 đặc biệt đáng nói: kết luận của ba PoC không đổi sau khi sửa, nên một người chỉ nhìn bảng kết quả sẽ không thấy gì khác; sai chỉ nằm ở chỗ PoC chưa từng được tìm đúng chỗ, và chỉ lộ ra khi so cột "bản ghi nguồn trong cửa sổ" với số bản ghi trong phạm vi. Mỗi lỗi có bài hỏi quy riêng (tests/unit/test_scope_and_caps.py, 15 bài).

7.5. Gọi LLM: miễn phí và độ tin cậy của endpoint

7.5.1. Đo tỷ lệ lỗi 404

Để chẩn đoán lỗi 404, endpoint chat-completions được gọi trực tiếp 15 lần với mô hình mặc định ban đầu: 14 lần HTTP 200 và 1 lần HTTP 404 model_not_found (nhà cung cấp Meta, mô hình meta/muse-spark-1.3-contributor). Tỷ lệ khoảng 1/15 (6,7%) nhỏ, nhưng một lần chạy PoC gồm nhiều lời gọi (kể cả hàng chục lời gọi nội bộ của các tác tử PEAK; số này chưa được đo), nên xác suất không gặp lỗi nào giảm nhanh. Ví dụ minh họa: với 6,7% mỗi lời gọi và giả sử 30 lời gọi, xác suất không lỗi chỉ khoảng 12%. Đây là lý do cơ chế gọi lại cần thiết chứ không phải tùy chọn.

Đổi sang auto giải quyết nguồn gốc lỗi vì không còn bị buộc vào một nhà cung cấp hay gặp sự cố. Thử sáu mô hình thay thế: chỉ auto chạy ổn định 3/3 lần; năm mô hình còn lại báo "not a valid model ID" trên endpoint hiện tại.

7.5.2. Thăm dò mô hình miễn phí

Danh mục OpenRouter được truy vấn qua /models, lọc các mô hình có giá prompt và completion bằng 0 (hai kết quả lyria là mô hình âm nhạc và một kết quả content-safety là mô hình kiểm duyệt nên bị loại khỏi thử nghiệm). Với 17 mô hình còn lại, mỗi mô hình được gọi một lần với yêu cầu trả đúng một đối tượng JSON ngắn (giới hạn 200 token).

Bảng 25. Kết quả thử một lần các mô hình miễn phí

Kết quả	Số mô hình	Mô hình
HTTP 200 và trả JSON hợp lệ	6	nvidia/nemotron-3-super-120b-a12b:free, nvidia/nemotron-3-ultra-550b-a55b:free, nvidia/nemotron-3-nano-omni-30b-a3b-reasoning:free, poolside/laguna-s-2.1:free, cohere/north-mini-code:free, liquid/lfm-2.5-2.6b:free
HTTP 200 nhưng không có JSON trong giới hạn 200 token	5	openrouter/free, apodex/apodex-1.1-mini:free, inclusionai/ling-3.0-flash-sante:free, dots-studio/dots-3-note-preview:free, nvidia/nemotron-3.5-lightning:free
HTTP 429 (nhà cung cấp quá tải hoặc giới hạn tốc độ)	4	inclusionai/ling-3.1-flash, poolside/laguna-xs-2.1:free, google/gemma-4-26b-a4b-it:free, google/gemma-4-31b-it:free
HTTP 403 (chỉ dùng trong môi trường tác tử riêng)	2	thinkingmachines/inkling:free, thinkingmachines/inkling-small:free

Hai điều kiện cần đọc cẩn thận. Một: nhóm "HTTP 200 nhưng không có JSON" có thể là mô hình suy luận dùng hết 200 token để nghĩ trước khi trả lời, nên thử nghiệm này không đủ để kết luận chúng vô dụng. Hai: đây là một lần thử, chưa lập; HTTP 429 có thể biến mất vào lúc khác. Kết quả chỉ cho biết "gọi được ngay lúc này".

7.5.3. Chạy trọn bốn PoC với một mô hình miễn phí

nvidia/nemotron-3-super-120b-a12b:free được chọn và chạy trọn bốn PoC (--model), hai lần: một lần trước và một lần sau khi sửa phạm vi truy vấn; số liệu ở chương này là của lần sau. Kết quả: cả bốn PoC cho cùng khuyến nghị như auto, PEAK được dùng ở cả bốn (used_peak = true), không có lần gọi lại nào phải ghi nhận, không có traceback. Judge cho Joomla là TRUE_POSITIVE 0,92. Bảng ABLE và kế hoạch của PEAK vẫn tuân thủ cấu trúc và nhắc đúng nguồn dữ liệu có trong CSDL (ví dụ ABLE của Joomla nói rằng telemetry có web_request với trường domain và cmdline, và gợi ý pivot sang process_creation để tìm hậu khai thác).

Kết luận cho yêu cầu ban đầu "gọi được API miễn phí hay không": **có**, ít nhất với một mô hình, và hệ thống chạy trọn vẹn. Đồng thời mục 6.2.2 bảo đảm rằng nếu không có khoá, hệ thống vẫn chạy ở chế độ không LLM.

7.6. Kiểm thử đơn vị và tính hồi quy

Bộ kiểm thử có 101 bài: 93 đạt và 8 bị bỏ qua (cần Splunk); ruff không báo lỗi. Hai nhóm bài có ý nghĩa cho luận văn.

- **Bất biến kiến trúc được khoá bằng kiểm thử:** chuỗi một phần không escalate; judge dưới ngưỡng không đổi luật; kết quả rỗng khi thiếu nguồn cho COLLECT_DATA_THEN_RERUN; advisor lỗi không đổi disposition; khoá API không có trong cấu hình.
- **Bài hồi quy cho lỗi thật:** EQUALS không khớp splunk-powershell.exe; EXISTS rỗng không khớp; retry_async thành công sau lỗi thoát qua và ném lại lỗi dai dẳng; CLI chạy được khi không có .env; phạm vi host rỗng được ghi nhận và chạy lại không lọc host (cả nhánh không hit và nhánh có hit ở host khác); báo cáo ghi hiển thị / tổng; MATCHES với regex thật tìm được; EXISTS không bị che bởi giới hạn quét.

Quá trình làm gọn kho cũng là một thực nghiệm hồi quy: sau khi xoá khoảng 28.000 dòng mã nguồn và các tệp kiểm thử của engine cũ, đường chạy PoC cho đúng cùng kết quả như trước (Joomla có hit, ba PoC còn lại rỗng; lúc đó chưa lộ ra các lỗi 8–10).

7.7. Đánh giá theo yêu cầu

Bảng 26. Đối chiếu yêu cầu và kết quả

Yêu cầu	Kết quả	Bằng chứng
---------	---------	------------

Yêu cầu	Kết quả	Bằng chứng
FR1, FR3	Đạt	Cổng Prepare; 200 bản ghi hiển thị tái lập qua ba cấu hình
FR2	Đạt	used_peak = true ở 4/4 PoC, với hai cấu hình LLM
FR4, FR5	Đạt (sau sửa)	Độ phủ theo cửa sổ, theo host và theo loại sự kiện; 5 disposition; lựa chọn xếp hạng
FR6, FR7	Đạt	summary.md, báo cáo, SPL, backlog
FR8	Đạt	--offline và bài test_cli_runs_without_any_llm_configuration
FR9	Đạt	--model và lần chạy Nemotron
NFR1	Đạt	Mọi hàng đến từ adapter; kiểm thử
NFR2	Đạt	Cùng số bản ghi hiển thị qua ba cấu hình
NFR3	Đạt từng phần	Gọi lại và fallback có kiểm thử; lỗi 404 thật chỉ có kiểm thử mô phỏng và quan sát gián tiếp
NFR4	Đạt	Quét không thấy khoá trong artifacts/runs/*, results, docs
NFR5	Đạt	Khoảng 8.700 dòng trong src/
NFR6	Đạt	Thẻ v6-engine-final, nhánh pre-peak-snapshot

7.8. Thời gian chạy

Phần tắt định nhanh: tìm kiếm trên 4,4 triệu dòng mất vài giây mỗi PoC (6 đến 16 giây gồm cả judge ở lần chạy cuối; quét 2.000 hàng thay vì 100 không làm chậm đáng kể). Phần LLM chiếm hầu hết thời gian. Lần chạy auto trước đó mất khoảng bốn phút cho cả bốn PoC, còn lần chạy cuối (ước lượng thô, không bấm giờ chính xác) mất khoảng 12 đến 15 phút cho mỗi cấu hình có LLM; với mô hình Meta Muse ban đầu mất 4 đến 8 phút cho mỗi PoC. Chênh lệch này cho thấy thời gian phụ thuộc mạnh vào dịch vụ LLM tại thời điểm chạy, các con số chỉ dùng để tham khảo.

7.9. Điều chưa được kiểm chứng

Để tránh hiểu nhầm về phạm vi, danh sách sau nêu rõ những điều đồ án chưa làm được.

1. **Splunk thật.** Chưa chạy adapter Splunk hoặc kiểm tra SPL do hệ thống sinh ra trên một máy chủ Splunk.
2. **`--research`.** Tác tử nghiên cứu của PEAK (cần máy chủ MCP) chưa được thử.
3. **Retry trên 404 thật.** Cơ chế gọi lại chỉ được kiểm thử bằng lỗi mô phỏng; trong các lần chạy cuối không gặp lại lỗi 404 nên chưa quan sát nó cứu một lần chạy thật.

4. **Adapter Splunk với các thay đổi truy xuất mới.** Giới hạn quét 2.000 hàng và tham số `require_nonempty` chưa được chạy trên Splunk thật; adapter này cũng chưa có độ phủ theo host hay theo loại sự kiện.
5. **Recall.** Chỉ đo được một pha tấn công thật (Joomla); ba pha còn lại thiếu dữ liệu nên chưa đo được khả năng phát hiện. Không có số liệu về độ chính xác tổng thể nào có thể tuyên bố.
6. **Số lần lặp.** Mỗi cấu hình chỉ chạy đầy đủ một đến vài lần; chưa có thống kê về độ biến thiên của judge hoặc advisor ngoài các con số rời rạc đã nêu.
7. **Chất lượng nội dung do PEAK viết.** Hệ thống kiểm tra PEAK có chạy và có trả cấu trúc, nhưng không có người chuyên gia nào chấm chất lượng ABLE hay kế hoạch.

Chương 8. Thảo luận

8.1. Những gì đồ án đạt được

Kết quả quan trọng nhất không nằm ở số liệu mà ở một thay đổi về bản chất của đầu ra. Phiên bản v6 cho người dùng một nhãn (MATCHED hoặc EMPTY) cùng nhận định judge; phiên bản v7 cho một khuyến nghị có cấu trúc: kết luận, mức tin cậy, lý do kiểm chứng được, giới hạn của kết luận, lựa chọn xếp hạng, câu hỏi và rủi ro. Cùng bốn PoC và cùng dữ liệu, sự khác biệt thể hiện rõ nhất ở ba PoC rỗng: nhãn "EMPTY" cũ dễ bị đọc là "không có gì", còn CLOSE_WITH_CAVEAT mới buộc người đọc đi qua ba giới hạn trước khi đóng.

Ba điểm thiết kế đáng giữ lại:

1. **Ranh giới tin cậy rõ ràng.** LLM đứng ở hai phía của bộ thực thi (trước: chuẩn bị; sau: giải thích) nhưng không bao giờ ở giữa. Nhờ đó khi LLM sai, thiệt hại giới hạn trong phần văn bản tham khảo.
2. **Luật tất định có giải thích.** Mỗi kết luận có lý do ghi bằng chữ và có kiểm thử khoá hành vi, nên người sản và người phản biện có thể truy vết vì sao hệ thống nói như vậy.
3. **Suy giảm duyên dáng.** Cùng một lệnh chạy được với PEAK, với mô hình miễn phí và không có LLM, và khuyến nghị thay đổi theo cách có thể dự đoán (mục 7.3).

8.2. So sánh với phương án thay thế

Bảng 27. So sánh ba cách tiếp cận

Tiêu chí	PEAK Assistant dùng riêng	Engine v6	Hệ thống v7
Chuẩn bị (ABLE, kế hoạch)	Có, tương tác	Tự xây, công kiểm tra trường	Có, qua PEAK, chạy hàng loạt
Thực thi trên telemetry	Qua MCP Splunk, do LLM điều khiển	Có, tất định	Có, tất định
Kết quả cuối	Tài liệu kế hoạch	Nhãn và nhận định judge	Khuyến nghị có lý do, giới hạn, rủi ro
Xử lý kết quả rỗng	Không áp dụng	Nhãn EMPTY	Độ phủ nguồn, COLLECT_DATA_THEN_RERUN
Chạy khi không có LLM	Không	Một phần	Có, đầy đủ
Kích thước mã	Lớn	~36.400 dòng	~8.700 dòng

Đây không phải so sánh hiệu năng; ba hệ thống phục vụ mục đích khác nhau. PEAK Assistant mạnh ở chỗ cộng tác với người sản qua giao diện trò chuyện, điều mà v7 chú ý không làm: v7 coi PoC là đầu vào đã được người sản chốt.

8.3. Hạn chế

8.3.1. *Khớp literal và độ phủ loại sự kiện*

Vị từ là literal: -enc không bắt -EncodedCommand, Logon Failed không bắt biến thể ngôn ngữ khác. Hệ thống ghi nhận giới hạn này nhưng chưa thử biến thể. Độ phủ theo **nguồn** không đủ: nguồn authentication có 20.657 bản ghi trong cửa sổ nhưng toàn bộ là đăng nhập thành công, trong khi PoC cần đăng nhập thất bại. Sau lượt rà soát cuối, báo cáo của kết quả rộng liệt kê các loại sự kiện thực có (authentication/4624 (20.657)) để người sẵn tự đối chiếu, nhưng hệ thống **vẫn chưa tự so** chúng với predicate: điều đó đòi hỏi PoC khai báo loại sự kiện cần có (ví dụ required_event_types), một thay đổi định dạng PoC còn để ngỏ.

8.3.2. *Phạm vi truy vấn ngầm, cửa sổ thời gian và giới hạn hàng*

Đây là điểm yếu thiết kế đã bộc lộ và được xử lý một phần ở lượt rà soát cuối. Phạm vi suy ra từ ABLE của PoC (host trong able.location, chuỗi cụ thể trong able.behavior) được thêm vào mọi bước. Cơ chế này có ý đồ tốt (PEAK muốn ABLE dẫn dắt truy vấn) nhưng nguy hiểm khi tên máy trong location chỉ mang tính mô tả: ở cả ba PoC rộng, máy đó không ghi nguồn tương ứng nên PoC chưa từng tìm trên dữ liệu thật (mục 7.2.2). Đồ án đã làm ba việc: hiển thị phạm vi, đếm độ phủ trong phạm vi, và chạy lại không lọc host khi phạm vi rộng. Nhưng gốc vấn đề vẫn còn: việc đọc tên máy từ văn xuôi bằng biểu thức chính quy vẫn là heuristic, có thể chọn nhầm token; một thiết kế sạch hơn là tách một trường host_scope tường minh trong PoC.

Về cửa sổ, mỗi PoC chạy trên một cửa sổ (một ngày hoặc 24 phút) và max_duration cắt về ba ngày, nên ba PoC rộng chỉ phủ 1 trên 28 ngày. Về giới hạn hàng, mỗi bước quét tối đa 2.000 hàng và giữ 100 hàng làm bằng chứng; báo cáo hiện ghi hiển thị / tổng và dấu $\geq$ khi quét chạm trần, nhưng số tổng khi bị cắt vẫn chỉ là cận dưới (PoC Joomla có khoảng 19,7 nghìn dòng Joomla trong cả tập dữ liệu). Muốn có số chính xác cần truy vấn COUNT riêng. Bản nháp SPL nay dùng cửa sổ của PoC (đổi sang epoch) nhưng chưa thêm bộ lọc host của phạm vi, nên bản nháp phát hiện rộng hơn PoC.

8.3.3. *Vai trò của máy và bối cảnh tổ chức*

Máy xuất hiện nhiều nhất trong kết quả Joomla là splunk-02, thực chất là máy thu log của bộ dữ liệu chứ không phải nạn nhân. Hệ thống chỉ nhắc người dùng xác nhận vai trò, vì nó không biết sơ đồ tài sản. Kết hợp với CMDB hoặc danh sách tài sản sẽ nâng chất lượng khuyến nghị nhưng nằm ngoài phạm vi.

8.3.4. Đo lường chi phí LLM

Số token chỉ tính judge và advisor. Các tác tử bên trong PEAK Assistant tạo ứng dụng khách riêng nên chưa được đo, trong khi đó mới là phần tốn nhất. Muốn đo cần can thiệp vào PEAK hoặc dùng bộ đếm ở tầng proxy.

8.3.5. Phụ thuộc vào một dự án chứng minh khái niệm

PEAK Assistant tự nhận là chưa qua kiểm thử bảo mật và không có bản phát hành PyPI. Hệ thống ghim commit để tái lập, nhưng điều đó đồng nghĩa với việc không tự nhận cập nhật và phải kiểm tra lại mỗi khi nâng cấp. Các hàm PEAK dùng (`able_table`, `plan_hunt`) là giao diện nội bộ, không có cam kết ổn định.

8.3.6. Tính không tất định của LLM

Cùng bằng chứng nhưng judge có thể cho độ tin cậy khác nhau (0,85 đến 0,97 trong các lần chạy). Thiết kế đã giới hạn ảnh hưởng của sự dao động này (chỉ đẩy một bậc, chỉ khi $\geq 0,7$), nhưng ngưỡng 0,7 và 0,8 được chọn theo kinh nghiệm chứ chưa hiệu chỉnh trên tập dữ liệu có nhãn.

8.4. Các mối đe dọa đối với tính hợp lệ

Quy mô nhỏ. Bốn PoC trên một bộ dữ liệu và một pha tấn công có nhãn. Đồ án chứng minh tính khả thi và các tính chất an toàn của thiết kế, không chứng minh hiệu năng phát hiện tổng quát.

Dữ liệu đã biết. BOTS v1 là bộ dữ liệu công khai mà cả PEAK Assistant lẫn mô hình LLM có thể đã thấy trong huấn luyện; việc judge nhận ra chuỗi `acunetix-wvs-test-for-some-inexistent-file` có thể phần nào do kiến thức sẵn có chứ không chỉ do suy luận trên bằng chứng. Với dữ liệu thật của một tổ chức, điều này không đảm bảo.

Thiên lệch người viết PoC. Các PoC được viết sau khi đã biết đáp án (từ bản hướng dẫn BOTS v1), nên kết quả Joomla có hit gần như là hiển nhiên. Giá trị kiểm chứng của Joomla là ở cách hệ thống hạ độ tin cậy và nêu giới hạn, không ở việc tìm ra hit.

Phụ thuộc dịch vụ. Tỷ lệ lỗi 404 và hành vi mô hình auto thay đổi theo thời điểm; kết quả thăm dò mô hình miễn phí là bức ảnh tại một thời điểm.

8.5. An toàn và trách nhiệm khi dùng

Khuyến nghị không phải kết luận pháp lý hay lệnh hành động. Hai rủi ro thực tế cần nêu rõ cho người dùng. Thứ nhất, **rò rỉ dữ liệu**: nội dung telemetry rút gọn và mô tả cấu trúc dữ liệu được gửi tới nhà cung cấp LLM; chế độ `--offline` hoặc mô hình cục bộ là lựa chọn cho dữ liệu nhạy cảm. Thứ hai, **tin cậy thái quá**: một báo cáo trình bày đẹp bằng tiếng Việt dễ khiến người đọc bỏ qua giới hạn. Thiết kế đã đặt giới hạn

lên cao trong báo cáo và dùng ngôn ngữ trực tiếp, nhưng không thể thay thế sự đào tạo người dùng. Cuối cùng, hệ thống không thực hiện hành động phản ứng nào; mọi bước cô lập, chặn hay xoá đều thuộc về con người.

8.6. Bài học rút ra

- Chạy bằng dữ liệu thật quan trọng hơn việc thêm kiểm thử. Các lỗi ở mục 7.4 hầu hết chỉ lộ ra khi chạy trên dữ liệu và LLM thật.
- Một kết luận đúng chưa chắc có lý do đúng. Ba PoC rỗng cho cùng khuyến nghị trước và sau khi sửa, nhưng trước đó chúng chưa từng tìm đúng chỗ. Chỉ khi đổi chiều cột "bản ghi nguồn trong cửa sổ" với "trong phạm vi lọc" và truy vấn trực tiếp dữ liệu thì mới thấy. Bài học: mọi bộ lọc ngầm phải hiện ra trong báo cáo, và mọi con số độ phủ phải đếm đúng phạm vi mà truy vấn thực sự chạy.
- Tự đổi chiều tài liệu với mã. Mô tả "MATCHES dùng re.search" trong bản thảo luận văn đúng ở tầng lọc nhưng sai ở tầng truy xuất; lỗi chỉ lộ ra khi đọc lại mã khi rà soát.
- Đọc báo cáo như một người dùng. Lỗi độ tin cậy HIGH vô căn cứ không làm hỏng bất kỳ bài kiểm thử nào, nó chỉ lộ ra khi đọc câu "chưa chứng minh được thành công" mà vẫn thấy HIGH.
- Đầu ra của LLM cần được kiểm tra về hình thức và về sự vắng mặt: cả hai lỗi 6 và 7 đều ở dạng "trông hợp lệ nhưng thực chất trống hoặc là thông báo lỗi".
- Làm gọn có thể là một đóng góp. Bỏ khoảng 28.000 dòng mã mà không đổi kết quả khiến hệ thống dễ giải thích hơn nhiều, nhưng cần thận trọng để việc bỏ đi không là mất mát.

Chương 9. Kết luận và hướng phát triển

9.1. Kết luận

Đồ án đã tái cấu trúc một kho mã sẵn mỗi đe dọa cỡ lớn thành một hệ thống nhỏ gọn, tích hợp PEAK Assistant của Cisco Talos cho pha Prepare, giữ pha Execute tất định trên telemetry, và bổ sung pha Act dưới dạng khuyến nghị có xếp hạng để người sẵn quyết định. Các mục tiêu đề ra ở mục 1.3 được đánh giá như sau.

- **Làm gọn kho:** mã nguồn giảm từ khoảng 36.400 xuống khoảng 8.700 dòng, số tệp kiểm thử từ khoảng 80 xuống 6 (101 bài kiểm thử, 93 đạt và 8 bỏ qua vì cần Splunk), bảo toàn khả năng khôi phục qua thẻ v6-engine-final.
- **Tích hợp PEAK Assistant:** cầu nối prepare.py gọi able_table và plan_hunt, chạy thành công trên cả bốn PoC với hai cấu hình LLM khác nhau, có gọi lại có backoff và quay về chế độ không LLM khi lỗi.
- **Khuyến nghị hỗ trợ quyết định:** năm loại khuyến nghị, độ tin cậy, lý do, giới hạn, lựa chọn xếp hạng, câu hỏi và rủi ro; mọi khuyến nghị có decision_required = true.
- **LLM tùy chọn:** hệ thống chạy trọn vẹn với --offline hoặc khi .env chưa điền, có kiểm thử riêng, và có thể chọn mô hình miễn phí qua --model; một mô hình miễn phí (nvidia/nemotron-3-super-120b-a12b:free) đã chạy hết bốn PoC cho cùng khuyến nghị như mô hình trả phí.
- **Thực nghiệm trung thực:** PoC Joomla có 200 bản ghi hiển thị (mỗi bước có ít nhất khoảng 2.000 hàng khớp) và khuyến nghị chuyển IR ở mức tin cậy trung bình, với lý do rõ ràng; ba PoC còn lại cho kết quả rỗng và được đóng kèm cảnh báo, không bị gọi là "sạch". Mười lỗi phát hiện khi chạy thật và khi rà soát cuối đều được ghi lại cùng cách xử lý.
- **Tài liệu:** hướng dẫn thực hành từ cài đặt đến viết PoC (Chương 6), tài liệu kiến trúc và định dạng PoC trong thư mục docs/.

Đóng góp có tính khái quát hơn là một mẫu kiến trúc: **dùng LLM ở hai đầu của một lối tất định, ghi rõ ranh giới tin cậy, và trình bày kết quả rỗng như một khẳng định có điều kiện.** Mẫu này không riêng cho sẵn mỗi đe dọa; nó áp dụng được cho bất kỳ quy trình nào mà LLM hỗ trợ con người ra quyết định trên dữ liệu.

9.2. Hạn chế còn lại

Tóm tắt những điều chưa làm hoặc chưa kiểm chứng (chi tiết ở các mục 7.9 và 8.3): chưa chạy trên Splunk thật (kể cả các thay đổi truy xuất mới); chưa thử tác tử nghiên cứu --research; độ phủ mới liệt kê loại sự kiện chứ chưa tự đối chiếu với predicate; phạm vi host vẫn suy ra từ văn xuôi bằng heuristic; số khớp khi quét chậm

trần chỉ là cận dưới; chi phí token của PEAK chưa đo; recall chỉ đo được một pha tấn công; judge chưa được hiệu chỉnh trên dữ liệu có nhãn.

9.3. Hướng phát triển

Các hướng được sắp theo mức độ cấp thiết, từ sửa các thiếu sót đã biết đến mở rộng.

Ngắn hạn (sửa thiếu sót).

1. Đếm số khớp thật bằng truy vấn COUNT riêng thay vì cận dưới khi lượt quét chạm giới hạn 2.000 hàng.
2. Tách trường `host_scope` tường minh trong PoC thay vì đọc tên máy từ `able.location` bằng heuristic, và đưa bộ lọc host vào bản nháp SPL.
3. Đối chiếu tự động theo loại sự kiện: PoC khai báo `native_type/event_id` cần có (ví dụ 4625), hệ thống so với cơ cấu loại sự kiện đã liệt kê và kết luận "thiếu dữ liệu" khi không có.
4. Chạy kiểm thử tích hợp với Splunk trong một container; cài đặt độ phủ theo cửa sổ, theo host và theo loại sự kiện cho adapter Splunk; kiểm tra giới hạn quét 2.000 hàng và tham số `require_nonempty` ở đó.

Trung hạn (nâng chất lượng).

5. Chạy PoC trên nhiều cửa sổ (quét toàn bộ 28 ngày theo từng ngày) và báo tỷ lệ ngày có hit.
6. Biến thể vị từ có kiểm soát: một tập quy tắc viết lại (ví dụ `-enc` và `-EncodedCommand`) áp dụng tất định chứ không để LLM tự nói.
7. Đo token của PEAK bằng proxy HTTP hoặc bằng cách bọc ứng dụng khách mô hình; báo cáo chi phí đầy đủ.
8. Hiệu chỉnh ngưỡng judge trên một tập có nhãn: lấy các pha tấn công khác của BOTS v1 và v2, đo tỷ lệ judge trùng nhãn.
9. Làm giàu bằng ngữ cảnh tài sản (vai trò máy, tài khoản dịch vụ) để khuyến nghị không còn phải nhắc "xác nhận vai trò máy".

Dài hạn (mở rộng phạm vi).

10. Hỗ trợ hai loại sản còn lại của PEAK: baseline (dùng `describe_data` làm nền) và M-ATH.
11. Vòng phản hồi: kết quả quyết định của người sản (chấp nhận, bác bỏ khuyến nghị) được ghi lại và dùng để cải thiện luật và lời nhắc.
12. Tích hợp với hệ thống quản lý sự cố (ticket) để gói `ir/` được chuyển tự động sau khi người sản xác nhận.

13. Đánh giá với người dùng thật: nhờ các nhà phân tích sẵn mỗi đe dọa dùng hệ thống trên các giả thuyết của họ và đo mức hữu ích của khuyến nghị, một điều đồ án này chưa làm được.

Tài liệu tham khảo

- [1] Splunk SURGe. *Introducing the PEAK Threat Hunting Framework*. Splunk Blog, 2023. https://www.splunk.com/en_us/blog/security/peak-threat-hunting-framework.html
- [2] Splunk SURGe. *Hypothesis-Driven Hunting with the PEAK Framework*. Splunk Blog, 2023. https://www.splunk.com/en_us/blog/security/peak-hypothesis-driven-threat-hunting.html
- [3] Splunk SURGe. *Baseline Hunting with the PEAK Framework*. Splunk Blog, 11/7/2023. https://www.splunk.com/en_us/blog/security/peak-baseline-hunting.html
- [4] Splunk SURGe. *Model-Assisted Threat Hunting (M-ATH) with the PEAK Framework*. Splunk Blog, 17/5/2023. https://www.splunk.com/en_us/blog/security/peak-framework-math-model-assisted-threat-hunting.html
- [5] Cisco Talos. *PEAK Assistant: an AI-backed threat hunting assistant that aligns to the PEAK framework* (mã nguồn mở, giấy phép MIT). <https://github.com/Cisco-Talos/PEAK-Assistant> (commit sử dụng: dfabbb0fbcc27292ecbb8e32beccda372bc0783).
- [6] Strom, B. E., Applebaum, A., Miller, D. P., Nickels, K. C., Pennington, A. G., Thomas, C. B. *MITRE ATT&CK: Design and Philosophy*. MITRE Corporation, technical report, 2018. <https://attack.mitre.org>
- [7] Bianco, D. J. *The Pyramid of Pain*. Enterprise Detection & Response (blog), 2013.
- [8] Bianco, D. J. *A Simple Hunting Maturity Model*. Enterprise Detection & Response (blog), 2015.
- [9] Wu, Q., Bansal, G., Zhang, J., et al. *AutoGen: Enabling Next-Gen LLM Applications via Multi-Agent Conversation*. arXiv:2308.08155, 2023.
- [10] Yao, S., Zhao, J., Yu, D., et al. *ReAct: Synergizing Reasoning and Acting in Language Models*. ICLR 2023. arXiv:2210.03629.
- [11] Zheng, L., Chiang, W.-L., Sheng, Y., et al. *Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena*. NeurIPS 2023 (Datasets and Benchmarks). arXiv:2306.05685.
- [12] Ji, Z., Lee, N., Frieske, R., et al. *Survey of Hallucination in Natural Language Generation*. ACM Computing Surveys 55(12), 2023.
- [13] Altman, D. G., Bland, J. M. *Absence of evidence is not evidence of absence*. BMJ 311, 485, 1995.

- [14] Lewis, P., Perez, E., Piktus, A., et al. *Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks*. NeurIPS 2020. arXiv:2005.11401.
- [15] Splunk. *Boss of the SOC (BOTS) Dataset Version 1*.
<https://github.com/splunk/botsv1>
- [16] Cichonski, P., Millar, T., Grance, T., Scarfone, K. *Computer Security Incident Handling Guide*. NIST Special Publication 800-61 Rev. 2, 2012.
- [17] OWASP Foundation. *OWASP Top 10 for Large Language Model Applications*.
<https://owasp.org/www-project-top-10-for-large-language-model-applications/>

Ghi chú: các tài liệu [1]–[5] và [15] được kiểm tra bằng tìm kiếm trên web vào thời điểm viết luận văn. Các tài liệu [6]–[14], [16], [17] được trích theo hiểu biết của tác giả về thông tin xuất bản; người nộp luận văn nên đối chiếu năm, số trang và đường dẫn với nguồn gốc trước khi nộp.

Phụ lục

Phụ lục A. Tập PoC mẫu

A.1. PoC Joomla (*pocs/poc-joomla-rce.json*)

```
{
  "poc_id": "poc-joomla-rce",
  "name": "Joomla RCE web compromise (BOTS v1 real attack)",
  "kind": "ttp",
  "summary": "Attacker scans and exploits Joomla search/mailto components on imreallynotbatman.com.",
  "topic": "web application exploitation",
  "able": {
    "actor": "",
    "behavior": "Exploit public-facing application (T1190) via Joomla search component",
    "location": "web traffic to imreallynotbatman.com",
    "evidence": "web_request telemetry; hit = site imreallynotbatman.com with /joomla/uri"
  },
  "research_refs": ["BOTS v1 walkthrough - web compromise phase", "MITRE ATT&CK T1190"],
  "scope": "stream:http 2016-08-10 window",
  "max_duration": "3d",
  "plan": "search_text over web telemetry for the victim site + joomla path",
  "steps": [
    {
      "step_id": "s1-victim-site",
      "description": "Request to compromised site",
      "target_field": "domain",
      "op": "EQUALS",
      "value": "imreallynotbatman.com",
      "source_kind": "web"
    },
    {
      "step_id": "s2-joomla-path",
      "description": "Joomla component path",
      "target_field": "cmdline",
      "op": "CONTAINS",
      "value": "/joomla/",
      "source_kind": "web"
    }
  ],
  "references": ["MITRE ATT&CK T1190"],
  "expected_chain": ["web_request", "exploitation"],
  "time_window": "2016-08-10T21:36:00Z/2016-08-10T22:00:00Z"
}
```

A.2. PoC mới, có ba bước (*pocs/examples/poc-web-scanner-acunetix.json*)

Ví dụ này khác PoC Joomla ở chỗ thêm bước tìm chuỗi acunetix và đặt bước nhận diện máy quét ở vị trí riêng.

```
{
  "poc_id": "poc-web-scanner-acunetix",
  "name": "Automated web vulnerability scanner against the Joomla site (Acunetix)",
  "kind": "behavior",
  "topic": "web application reconnaissance",
  "able": {
    "actor": "",
    "behavior": "Active scanning of a public-facing web application (T1595.002) preceding exploitation (T1190)",
    "location": "web traffic to imreallynotbatman.com",
    "evidence": "web_request telemetry; hit = domain imreallynotbatman.com with an acunetix probe uri and /joomla/ paths"
  },
  "research_refs": ["MITRE ATT&CK T1595.002 Vulnerability Scanning", "BOTS v1 walkthrough - web compromise phase"],
  "scope": "stream:http for imreallynotbatman.com on 2016-08-10 21:36-22:00",
  "max_duration": "3d",
  "plan": "search_text over web telemetry for the victim site, then the acunetix probe string, then the Joomla path",
}
```

```

"time_window": "2016-08-10T21:36:00Z/2016-08-10T22:00:00Z",
"steps": [
  {"step_id": "s1-victim-site", "target_field": "domain", "op": "EQUALS",
"value": "imreallynotbatman.com", "source_kind": "web"},
  {"step_id": "s2-acunetix-probe", "target_field": "cmdline", "op": "CONTAINS",
"value": "acunetix", "source_kind": "web"},
  {"step_id": "s3-joomla-enum", "target_field": "cmdline", "op": "CONTAINS",
"value": "/joomla/", "source_kind": "web"}
],
"references": ["MITRE ATT&CK T1595.002", "MITRE ATT&CK T1190"],
"expected_chain": ["web_request"]
}

```

Chạy với --offline trên BOTS v1: 204 bản ghi hiển thị (100 / ≥ 1.999 , 6 và 100 / ≥ 2.000 cho từng bước), khuyến nghị INVESTIGATE_FURTHER (MEDIUM).

A.3. Bảng trường của PoC

Bảng 28. Các trường của tệp PoC

Trường	Bắt buộc	Mô tả
poc_id, name, kind, summary	poc_id, name	Định danh và mô tả ngắn
topic	Có	Chủ đề sẵn (PEAK: select topic)
able.actor	Không (được để trống)	Tác nhân đe dọa
able.behavior, able.location, able.evidence	Có	Ba thành phần còn lại của ABLE
research_refs	Có	Tài liệu nghiên cứu đã đọc
scope	Có	Hệ thống, dữ liệu và khoảng thời gian
max_duration	Có	Thời lượng tối đa, ví dụ 3d
plan	Có	Kế hoạch tóm tắt
steps[]	Có	step_id, description, target_field, op, value, source_kind
fallbacks[]	Không	Bước thay thế khi lượt đầu rỗng
references[], expected_chain[]	Không	Tham chiếu MITRE; chuỗi quan sát kỳ vọng
time_window	Không	Cửa sổ mặc định START/END (ISO-8601 UTC)

Giá trị hợp lệ: op thuộc {EQUALS, CONTAINS, STARTS_WITH, ENDS_WITH, MATCHES, EXISTS}; source_kind thuộc {process, web, dns, authentication, file, smb}.

Phụ lục B. Trích báo cáo khuyến nghị mẫu

Dưới đây là phần đầu của recommendation.md cho PoC Joomla (lần chạy auto); các mục từ "Bằng chứng" trở đi được lược bớt.

```

# Khuyến nghị hunt – poc-joomla-rce

PoC: Joomla RCE web compromise (BOTS v1 real attack)
Cửa sổ dữ liệu: 2016-08-10T21:36:00Z/2016-08-10T22:00:00Z
Nguồn dữ liệu: CDB data/botsv1_eval.sqlite

```

PEAK Assistant: đã dùng (ABLE + hunt plan)

Khuyến nghị

Chuyển IR (escalate)

ESCALATE_TO_IR – độ tin cậy trung bình (MEDIUM).

> Đây là gợi ý hỗ trợ quyết định. Người sẵn mỗi đe dọa là người
> quyết định cuối cùng; hệ thống không tự hành động.

Lý do

- 2/2 bước PoC có kết quả, tổng 200 bản ghi khớp.
- Khoảng thời gian hit: 2016-08-10T21:36:45Z → 2016-08-10T21:40:57Z.
- Judge (advisory) đánh giá TRUE_POSITIVE, độ tin cậy 0.85.
- Độ tin cậy bị hạ xuống MEDIUM: PoC không có bước nào kiểm tra kết quả (status/action) nên chưa chứng minh được tấn công thành công.

Cần lưu ý (giới hạn của kết luận)

- Khớp predicate literal chứng minh có hoạt động tương ứng trong dữ liệu; tự nó chưa chứng minh thành công hay tác động.
- Bước s1-victim-site: chỉ hiển thị 100 bản ghi trong ít nhất 1999 bản ghi khớp (quét đã dùng ở giới hạn hàng nên tổng thực tế có thể lớn hơn).
- Bước s2-joomla-path: chỉ hiển thị 100 bản ghi trong ít nhất 2000 bản ghi khớp.

Các lựa chọn cho người quyết định (xếp theo ưu tiên)

1. ESCALATE_TO_IR – chuyển gói bằng chứng cho IR; trước khi cô lập, xác nhận vai trò thật của splunk-02.
2. INVESTIGATE_FURTHER – pivot theo splunk-02 cùng khoảng thời gian.
3. TUNE_POC_OR_CLOSE – thêm điều kiện loại trừ rồi chạy lại.

Bảng chứng

Bước	Predicate	Nguồn	Nguồn/cửa sổ	Trong phạm vi
Khớp (hiển thị / tổng)				
s1-victim-site	domain EQUALS imreallynotbatman.com	web	12,546	12,546
100 / ≥1999				
s2-joomla-path	cmdline CONTAINS /joomla/	web	12,546	12,546
100 / ≥2000				

Judge (LLM, chỉ tham khảo)

TRUE_POSITIVE – 0.85. Requests to /acunetix-wvs-test-for-some-inexistent-file and random 8-character URIs followed by Joomla component enumeration within a tight 21:36-21:40 window match automated Joomla vulnerability scanning ...

Rủi ro nếu quyết định sai

- Chưa có bước kiểm tra status/action nên chưa chứng minh RCE thành công.
- Mẫu có /acunetix-wvs-test-for-some-inexistent-file gợi ý scanner Acunetix.
- Việc escalate lên IR khi chưa xác nhận thành công có thể lãng phí nguồn lực.

Act: bản nháp phát hiện (SPL) – trạng thái DRAFT, chưa chạy trên Splunk thật; cửa sổ lấy từ PoC (epoch UTC)

```
search index="botsv1" domain="imreallynotbatman.com" match(cmdline, "(?i)/joomla/")  
earliest=1470864960 latest=1470866400  
| table _time, host, user, image, cmdline, domain, file_path, action
```

Phụ lục C. Tham chiếu dòng lệnh và biến môi trường

C.1. Dòng lệnh

```
python main.py [--poc FILE ...] [--poc-dir DIR] [--window START/END]  
               [--provider {cdb,splunk}] [--db PATH]  
               [--splunk-url URL] [--splunk-user USER] [--splunk-index INDEX] [--splunk-  
manifest FILE]
```

```
SECONDS] [--env FILE] [--model NAME] [--offline] [--research] [--peak-timeout  
[--out DIR]
```

Mã thoát khác 0 nếu có PoC bị lỗi nạp hoặc lỗi cổng Prepare; các PoC còn lại vẫn được chạy.

C.2. Biến môi trường

Bảng 29. *Biến môi trường*

Biến	Mặc định	Ý nghĩa
LLM_ENDPOINT	(không)	URL chat-completions tương thích OpenAI
LLM_API_KEY	(không)	Khoá API; không bao giờ ghi vào tệp kết quả
LLM_MODEL	(không)	Tên mô hình; --model ghi đè
LLM_TIMEOUT	600	Hạn của mỗi lời gọi (giây)
LLM_MAX_TOKENS	16000	Giới hạn token đầu ra
SPLUNK_URL	https://localhost:8089	Địa chỉ REST của Splunk
SPLUNK_USER	admin	Tài khoản Splunk
SPLUNK_PASSWORD	(bắt buộc với --provider splunk)	Mật khẩu Splunk
SPLUNK_INDEX	botsv1	Chỉ mục Splunk

Biến môi trường của tiến trình, nếu có, được ưu tiên hơn giá trị trong .env; --model ưu tiên hơn cả hai.

Phụ lục D. Lược đồ `recommendation.json`

Bảng 30. *Các khoá cấp cao của recommendation.json*

Khoá	Kiểu	Nội dung
poc_id, poc_name	chuỗi	Định danh PoC
disposition, disposition_label	chuỗi	Khuyến nghị và nhãn tiếng Việt
confidence	chuỗi	HIGH, MEDIUM, LOW
headline	chuỗi	Câu tóm tắt
reasons, caveats	danh sách chuỗi	Lý do và giới hạn
options	danh sách	Mỗi phần tử có action, rank, rationale
evidence	đối tượng	window, steps[] (step_id, description, predicate, source_kind, row_count, source_rows_in_window, source_rows_in_scope, matched_total, scan_truncated), scope (host, actor, observables), scope_empty_sources, capped_steps, source_breakdown, source_hosts, unscoped_probe,

Khoá	Kiểu	Nội dung
		matched_steps, total_steps, observations, first_seen, last_seen, pivots, top_values, samples, chain_complete, missing_sources, unverifiable_sources
judge	đối tượng	verdict, confidence, rationale, notes
next_steps, questions_for_hunter, risks	danh sách	Do advisor tạo
decision_required	boolean	Luôn true
advisor_note	chuỗi	Ghi chú về trạng thái advisor (ví dụ khi thất bại)
execution	đối tượng	verdict (MATCHED/EMPTY), window, scope_note, ir_escalation_path
peak	đối tượng	used_peak, able_markdown, hunt_plan_markdown, research_markdown, notes
meta	đối tượng	data_source, used_peak, peak_notes, able_file, plan_file, llm_calls, llm_tokens, hunt_seconds, ledger_path

Phụ lục E. Danh sách kiểm thử

Bảng 31. Phân bố 101 bài kiểm thử theo tệp

Tệp	Số bài	Nội dung
test_pipeline.py	25	Luật khuyến nghị, advisor, cấu hình LLM, PEAK, độ phủ CDB, CLI
test_poc.py	30	Mô hình PoC, toán tử, khớp chính xác, tinh chỉnh, công Prepare
test_splunk_live_adapter.py	16	Adapter Splunk (8 bài cần máy chủ thật, tự bỏ qua)
test_act.py	8	Bản nháp SPL, backlog, ghi chú stakeholder
test_v5_adapters.py	5	Hợp đồng adapter và kiểm soát truy vấn
test_peak_execute.py	2	Phân tích kế hoạch PEAK thành quan sát cụ thể
test_scope_and_caps.py	15	Phạm vi host ngầm, giới hạn hàng, MATCHES/EXISTS, độ phủ theo loại sự kiện, cửa sổ SPL

Các bài của test_pipeline.py (tên rút gọn): test_disposition_rules (11 tổ hợp);
test_escalate_is_high_only_when_an_outcome_field_is_tested;
test_empty_result_never_reads_as_clean_when_source_missing;
test_advisor_parses_json_and_survives_garbage;
test_advisor_retries_until_usable_and_accepts_drifted_shapes;
test_llm_settings_from_env_file; test_llm_settings_rejects_placeholders;
test_prepare_without_llm_uses_poc_plan_and_says_so;
test_prepare_degrades_when_peak_agents_fail;
test_prepare_retries_a_transient_peak_failure;
test_retry_async_recovers_from_transient_errors_and_reraises_persistent_ones;
test_cdb_source_presence_and_description; test_cli_offline_end_to_end;
test_cli_requires_a_poc; test_cli_runs_without_any_llm_configuration.

Lệnh chạy: python -m pytest tests -q (kết quả: 93 đạt, 8 bỏ qua) và python -m ruff check src tests (không báo lỗi).

Phụ lục F. Kết quả từng lần chạy

Bảng 32. Tổng hợp các lần chạy cuối (sau khi sửa phạm vi truy vấn) đã dùng trong luận văn

Cấu hình	PoC	Khuyến nghị	Tin cậy	Lỗi gọi LLM	Token	Thời gian Execute (giây)	Judge
auto	joomla	ESCALATE_TO_IR	MEDIUM	2	9.524	16,1	TRUE_POSITIVE 0,85
auto	bruteforce	CLOSE_WITH_CAVEAT	MEDIUM	1	7.004	6,1	(không có hit)
auto	c2-beacon	CLOSE_WITH_CAVEAT	MEDIUM	1	6.695	6,2	(không có hit)
auto	pdf-exploit	CLOSE_WITH_CAVEAT	MEDIUM	1	8.087	8,8	(không có hit)
Nemotron free	joomla	ESCALATE_TO_IR	MEDIUM	2	7.280	8,3	TRUE_POSITIVE 0,92
Nemotron free	bruteforce	CLOSE_WITH_CAVEAT	MEDIUM	1	4.814	6,1	(không có hit)
Nemotron free	c2-beacon	CLOSE_WITH_CAVEAT	MEDIUM	1	6.362	6,4	(không có hit)
Nemotron free	pdf-exploit	CLOSE_WITH_CAVEAT	MEDIUM	1	4.949	9,3	(không có hit)
--offline	joomla	INVESTIGATE_FURTHER	MEDIUM	0	0	—	—
--offline	ba PoC còn lại	CLOSE_WITH_CAVEAT	MEDIUM	0	0	—	—

Phụ lục G. Cấu trúc thư mục kho

```
AI_Agent_Hunting/
├── main.py                # điểm vào: gọi hunting.cli
├── pyproject.toml         # phụ thuộc; extra [peak] và [dev]
├── .env.example           # mẫu cấu hình LLM
├── pocs/                  # 4 PoC; examples/ chứa PoC mẫu
├── src/hunting/
│   ├── llm.py  prepare.py  recommend.py  report.py  pipeline.py  cli.py
│   ├── poc/          # mô hình PoC, tác tử thực thi, judge
│   ├── adapters/     # CDB (SQLite) và Splunk
│   ├── act/          # SPL, backlog, stakeholder
│   ├── peak.py  contracts/  capabilities/  controller/  query_safety/
├── scripts/            # nạp BOTS v1 vào SQLite
├── tests/unit/          # 101 bài kiểm thử
├── results/botsv1-peak-run/# kết quả đã commit
├── docs/                # kiến trúc, định dạng PoC, báo cáo, thesis/, archive/
```

Phụ lục H. Bảng thuật ngữ

Bảng 33. Thuật ngữ và từ viết tắt

Thuật ngữ	Giải nghĩa
ABLE	Actor, Behavior, Location, Evidence: mô hình mô tả giả thuyết của PEAK
Advisor	Lời gọi LLM sinh bước tiếp theo, câu hỏi và rủi ro; không đổi kết luận
Adapter	Lớp truy cập telemetry (CDB/SQLite hoặc Splunk)
ATT&CK	Cơ sở tri thức chiến thuật và kỹ thuật của MITRE
BOTS	Boss of the SOC, bộ dữ liệu và cuộc thi của Splunk
CDB	Cơ sở dữ liệu telemetry dạng SQLite của dự án
Disposition	Loại khuyến nghị (năm giá trị ở mục 4.6.1)
Execute	Pha thực thi của PEAK; trong đề tài là phần tắt định
IR	Incident Response: ứng cứu sự cố
Judge	Lời gọi LLM đánh giá bản ghi khớp; chi tham khảo
LLM	Mô hình ngôn ngữ lớn
M-ATH	Model-Assisted Threat Hunt: sẵn có hỗ trợ mô hình
MCP	Model Context Protocol: giao thức nối công cụ ngoài với LLM
PEAK	Prepare, Execute, Act with Knowledge
PoC	Proof of Concept: ở đây là giả thuyết đã cụ thể hoá thành vị từ
Predicate (vị từ)	Điều kiện trường - toán tử - giá trị kiểm tra trên bản ghi
SPL	Search Processing Language của Splunk
Telemetry	Dữ liệu quan sát từ hệ thống (log, sự kiện)
TTP	Tactics, Techniques and Procedures